

0.1 Thiết kế kiến trúc

0.1.1 Lựa chọn kiến trúc phần mềm

a, Nền tảng kiến trúc và lý do lựa chọn

Hệ thống IAM được xây dựng dựa trên sự kết hợp của hai kiến trúc bổ sung cho nhau: kiến trúc Microservices để phân tách các miền nghiệp vụ theo ranh giới rõ ràng, và kiến trúc hướng sự kiện (Event-Driven Architecture) để điều phối giao tiếp bất đồng bộ giữa các service. Mỗi lựa chọn đều được phân tích so sánh với phương án thay thế nhằm chứng minh sự phù hợp với đặc thù bài toán.

Kiến trúc microservices phân chia ứng dụng thành các dịch vụ nhỏ, độc lập, mỗi dịch vụ đảm nhiệm một miền nghiệp vụ (bounded context) cụ thể và có thể được phát triển, kiểm thử, triển khai, mở rộng hoàn toàn độc lập với các dịch vụ còn lại. Theo khảo sát CNCF Annual Cloud Native Survey 2025, 46% backend developer đang tích cực triển khai microservices và 89% tổ chức đã áp dụng công nghệ cloud-native **cncf_survey_2025**. Bảng 1 so sánh với kiến trúc nguyên khối (Monolithic) theo các tiêu chí liên quan:

Bảng 1: So sánh kiến trúc Microservices và Monolithic

Tiêu chí	Monolithic	Microservices
Độ phức tạp ban đầu	Thấp — một codebase duy nhất	Cao — nhiều service, nhiều module
Triển khai	Toàn bộ hệ thống phải deploy cùng lúc	Từng service deploy hoàn toàn độc lập
Khả năng mở rộng	Phải scale toàn bộ ứng dụng	Scale riêng từng service theo nhu cầu
Xử lý lỗi	Lỗi một module có thể ảnh hưởng toàn hệ thống	Lỗi được cô lập tại ranh giới từng service
Phù hợp khi	Team nhỏ, domain đơn giản	Domain phức tạp, nhiều bounded context tách biệt

Kiến trúc hướng sự kiện (Event-Driven Architecture — EDA) là mô hình trong đó các thành phần giao tiếp thông qua việc phát và tiêu thụ sự kiện bất đồng bộ thay vì gọi trực tiếp lẫn nhau theo kiểu đồng bộ. Trong mô hình Publish/Subscribe, bên phát sự kiện không cần biết có bao nhiêu bên tiêu thụ đang lắng nghe — thêm mới hoặc thay đổi một subscriber không đòi hỏi chỉnh sửa publisher, tạo ra sự tách rời (loose coupling) tự nhiên. Bảng 2 so sánh với REST đồng bộ:

Bảng 2: So sánh giao tiếp Event-Driven (Kafka) và REST đồng bộ

Tiêu chí	REST đồng bộ	Event-Driven (Kafka)
Coupling	Chặt — caller phải biết endpoint của callee	Lỏng — chỉ cần biết tên event topic
Khả năng chịu lỗi	Thấp — consumer down gây lỗi tức thì	Cao — event được giữ lại chờ consumer phục hồi
Hiệu năng	Blocking — caller chờ response	Non-blocking — fire-and-forget
Fan-out	Phức tạp — gọi lần lượt từng service	Tự nhiên — nhiều consumer group cùng nhận
Audit trail	Không có sẵn	Có — Kafka log giữ lại toàn bộ sự kiện
Độ phức tạp vận hành	Thấp	Cao — cần quản lý Kafka cluster

b, Áp dụng vào hệ thống IAM

Dựa trên hai nền tảng kiến trúc trên, hệ thống IAM được tổ chức thành bốn service độc lập giao tiếp với nhau qua hai kênh: REST đồng bộ (qua gateway) cho luồng chính từ người dùng, và Kafka bất đồng bộ cho các sự kiện nghiệp vụ nội bộ.

Về phân chia service, bốn bounded context được tách biệt theo đặc thù kỹ thuật và yêu cầu hiệu năng riêng biệt. *iam-auth-service* là service có yêu cầu hiệu năng cao nhất — đảm nhiệm toàn bộ runtime xác thực gồm xử lý luồng OAuth 2.0, điều phối các bước MFA, ký và kiểm tra JWT, quản lý phiên làm việc; service này duy trì hai tầng cache (Caffeine cho cấu hình luồng xác thực theo từng ứng dụng, Redis cho mã xác thực tạm thời) và hầu như không truy vấn cơ sở dữ liệu trong luồng xử lý thông thường. *iam-identity-service* đảm nhiệm toàn bộ vòng đời người dùng (tiếp nhận, thôi việc, nghỉ phép, luân chuyển) và quy trình CAB phê duyệt yêu cầu phân quyền — service có logic nghiệp vụ phức tạp nhất, truy vấn Oracle nhiều nhất và là đầu mối phát toàn bộ sự kiện Kafka. *iam-app-service* quản lý mặt phẳng cấu hình: danh mục ứng dụng, OAuth2 client, cây luồng xác thực, tài nguyên và ma trận quyền mặc định theo Role × Position — service có tần suất đọc cao, ít thay đổi và không tham gia vào luồng xác thực runtime. *iam-gateway* là điểm vào duy nhất của hệ thống, thực hiện nhiệm vụ duy nhất là route mỗi request đến service đích để thực hiện các yêu cầu từ *client*.

Về vấn đề giao tiếp giữa các Microservice, *iam-identity-service* và *iam-app-service* đóng vai trò publisher; *iam-auth-service* và *iam-notify-service* đóng vai trò consumer. Bảng 3 liệt kê các topic Kafka và luồng xử lý tương ứng:

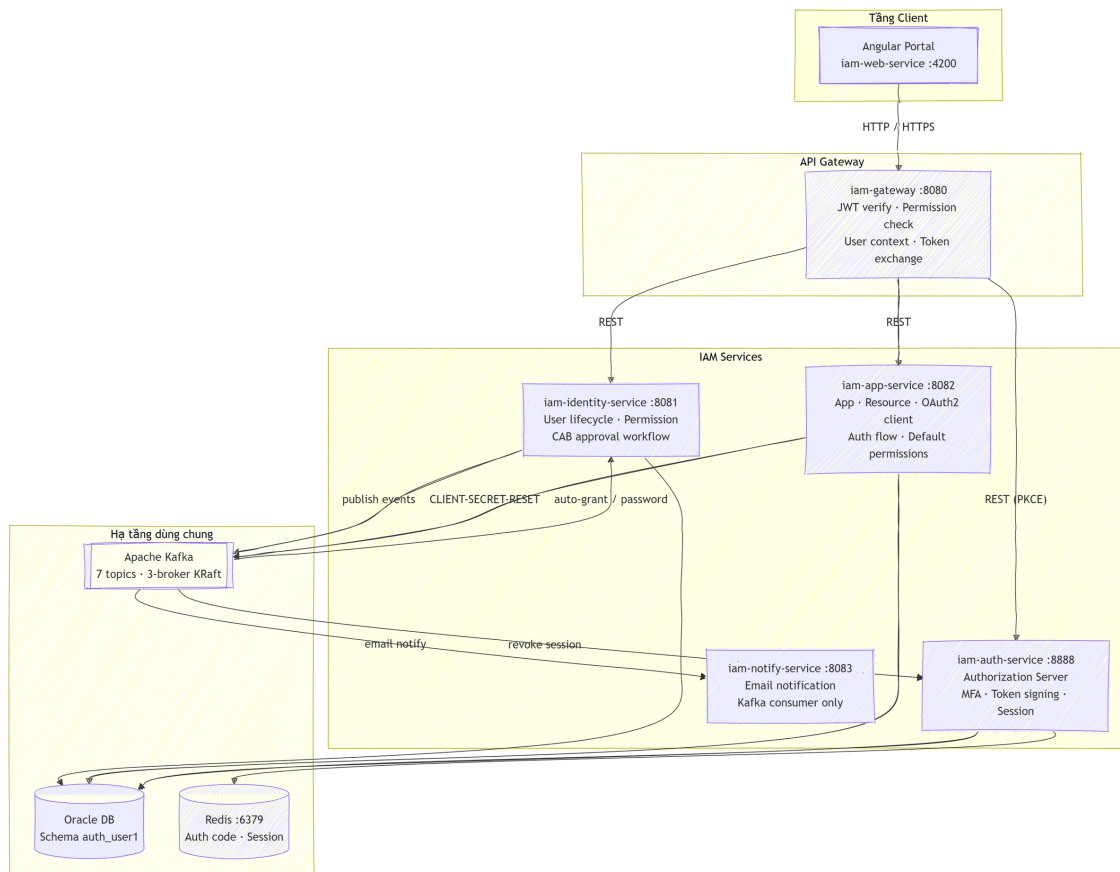
Bảng 3: Các Kafka topic trong hệ thống IAM

Topic	Publisher	Consumer	Kích hoạt khi
CREATE-SUCCESS-USER-NOTIFY	identity	notify	Tạo mới / tiếp nhận người dùng
DEFAULT-GRANT-PERMISSION-USER	identity	identity	Tiếp nhận / luân chuyển / gán role
USER-CHANGED-PASSWORD	identity	auth	Đổi / đặt lại mật khẩu
REQUEST-PERMISSION-NOTIFY	identity	notify	Gửi yêu cầu phân quyền chính thức
APPROVE-PERMISSION-NOTIFY	identity	notify	CAB phê duyệt hoặc từ chối
REVOKED-PERMISSION-NOTIFY	identity	auth, notify	Thu hồi quyền ứng dụng / tài nguyên
CLIENT-SECRET-RESET-NOTIFY	app	auth	Đặt lại client secret

Topic *REVOKED-PERMISSION-NOTIFY* minh họa rõ nhất lợi thế fan-out: khi quyền bị thu hồi, một sự kiện duy nhất kích hoạt đồng thời *iam-auth-service* vô hiệu hóa phiên làm việc ngay lập tức và *iam-notify-service* gửi email thông báo — hai hành động độc lập, không có sự phụ thuộc nào giữa hai consumer. Nguyên tắc bất biến xuyên suốt toàn bộ hệ thống là mọi sự kiện đều được phát sau khi một giao dịch của database hoàn toàn thành công, đảm bảo tính nhất quán dữ liệu kể cả khi message broker gặp sự cố.

0.1.2 Thiết kế tổng quan

Với kiến trúc Microservices, thiết kế tổng quan không mô tả các gói bên trong một ứng dụng đơn mà mô tả sự phân chia và phụ thuộc giữa các service — mỗi service là một đơn vị triển khai độc lập tương ứng với một miền nghiệp vụ (bounded context) xác định. Hình 0.1 trình bày kiến trúc tổng thể của hệ thống IAM với bốn service nghiệp vụ chính, một service thông báo và ba thành phần hạ tầng dùng chung.



Hình 0.1: Sơ đồ kiến trúc tổng thể hệ thống IAM

Hệ thống IAM được tổ chức thành năm service độc lập, mỗi service đảm nhiệm một miền nghiệp vụ riêng biệt và không có service nào tiếp nhận kết nối trực tiếp từ phía client ngoài API Gateway. Vai trò và mục đích của từng service được trình bày dưới đây:

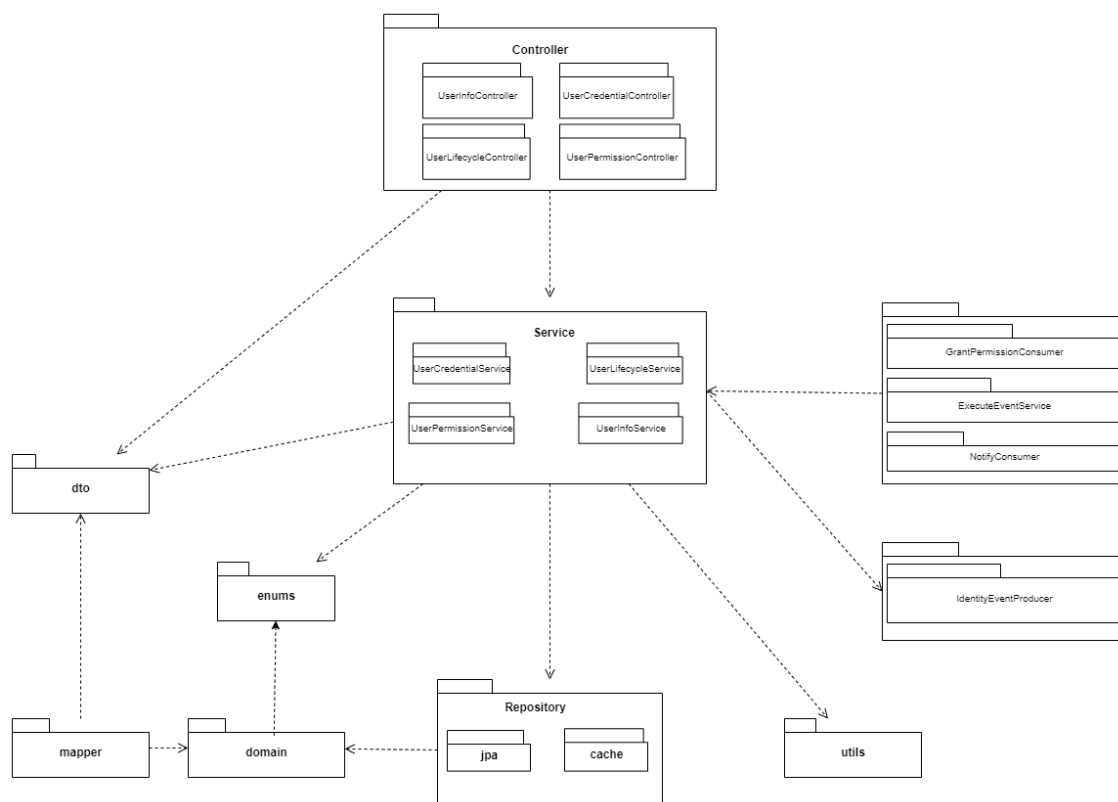
- **iam-gateway** — API Gateway, điểm vào duy nhất của toàn bộ hệ thống. Mọi yêu cầu từ Angular Portal đều đi qua gateway trước khi được định tuyến đến service đích. Gateway thực hiện bốn nhiệm vụ tuần tự: xác minh chữ ký JWT, kiểm tra quyền truy cập theo route, gắn thông tin người dùng vào header và trao đổi token người dùng thành token dịch vụ.
- **iam-auth-service** — Authorization Server, miền xác thực. Service chịu trách nhiệm xử lý toàn bộ luồng OAuth 2.0, điều phối các bước MFA, ký và kiểm tra JWT, quản lý phiên làm việc. Đây là service có yêu cầu hiệu năng cao nhất, duy trì hai tầng cache (Caffeine và Redis) để giảm thiểu truy vấn cơ sở dữ liệu trong luồng xử lý thông thường.
- **iam-identity-service** — Miền quản lý danh tính và phân quyền. Service đảm nhiệm toàn bộ vòng đời người dùng (tiếp nhận, thôi việc, nghỉ phép, luân chuyển) và quy trình CAB phê duyệt yêu cầu phân quyền. Đây là service có

logic nghiệp vụ phức tạp nhất và là đầu mối phát toàn bộ sự kiện Kafka trong hệ thống.

- **iam-app-service** — Miền cấu hình hệ thống. Service quản lý mặt phẳng cấu hình bao gồm danh mục ứng dụng, tài nguyên, OAuth2 client, cây luồng xác thực và ma trận quyền mặc định theo Role $\times$ Position. Service có tần suất đọc cao, ít thay đổi và không tham gia vào luồng xác thực runtime.
- **iam-notify-service** — Service thông báo, đóng vai trò Kafka consumer thuần túy. Service lắng nghe các topic từ *iam-identity-service* và *iam-app-service* để gửi email thông báo đến người dùng. Không có HTTP endpoint nào được expose ra ngoài.

Về phụ thuộc giữa các service, cấu trúc phân tầng là một chiều và không bỏ qua tầng. Tầng trên (*Angular Portal*) chỉ giao tiếp với *iam-gateway*; gateway định tuyến đến các service nghiệp vụ; các service nghiệp vụ truy cập trực tiếp vào hạ tầng (Oracle, Redis, Kafka); *iam-notify-service* chỉ nhận từ Kafka, không gọi bất kỳ service nào khác. Không có service nào gọi trực tiếp vào service khác theo kiểu đồng bộ — mọi phối hợp nội bộ đều đi qua Kafka.

Trong số các service trên, *iam-identity-service* là service trung tâm của bài toán phân quyền. Hình 0.2 trình bày biểu đồ gói UML của service này, được tổ chức theo kiến trúc phân tầng nghiêm ngặt.



Hình 0.2: Biểu đồ gói UML của iam-identity-service

Gói *controller* chịu trách nhiệm tiếp nhận các yêu cầu HTTP từ phía client, kiểm tra tính hợp lệ của đầu vào ở mức sơ bộ và chuyển tiếp sang tầng nghiệp vụ để xử lý. Gói này chỉ phụ thuộc vào *service*, tách biệt hoàn toàn việc xử lý giao thức HTTP ra khỏi logic nghiệp vụ.

Gói *service* nhận yêu cầu từ *controller*, thực thi toàn bộ logic nghiệp vụ của hệ thống và phối hợp với *repository* để truy cập dữ liệu. Đây là tầng trung tâm, nơi tập trung mọi quy tắc xử lý và điều phối các luồng nghiệp vụ phức tạp như quy trình phê duyệt phân quyền hay vòng đời nhân sự.

Gói *repository* đóng vai trò giao diện truy cập dữ liệu, cung cấp các thao tác đọc, ghi và cập nhật lên cơ sở dữ liệu Oracle thông qua Spring Data JPA. Gói này gồm hai sub-package: *repository.jpa* cho các truy vấn thông thường và *repository.cache* cho các thao tác cần tối ưu hiệu năng.

Gói *domain* chứa các thực thể JPA, mỗi thực thể ánh xạ trực tiếp đến một bảng trong cơ sở dữ liệu Oracle. Đây là tầng dữ liệu thấp nhất, không phụ thuộc vào bất kỳ tầng nào phía trên.

Gói *kafka.consumer* đảm nhiệm việc lắng nghe và tiêu thụ các sự kiện từ các topic Kafka. Sau khi nhận sự kiện, consumer không tự xử lý mà ủy thác toàn bộ cho *service*, đảm bảo logic nghiệp vụ được tập trung tại một nơi duy nhất.

Các gói *dto*, *mapper*, *enums* và *utils* là các gói hỗ trợ không thuộc tầng nghiệp vụ cụ thể nào. Chúng cung cấp các đối tượng truyền dữ liệu, bộ chuyển đổi giữa entity và DTO, hằng số trạng thái và các phương thức tiện ích dùng chung cho toàn bộ service.

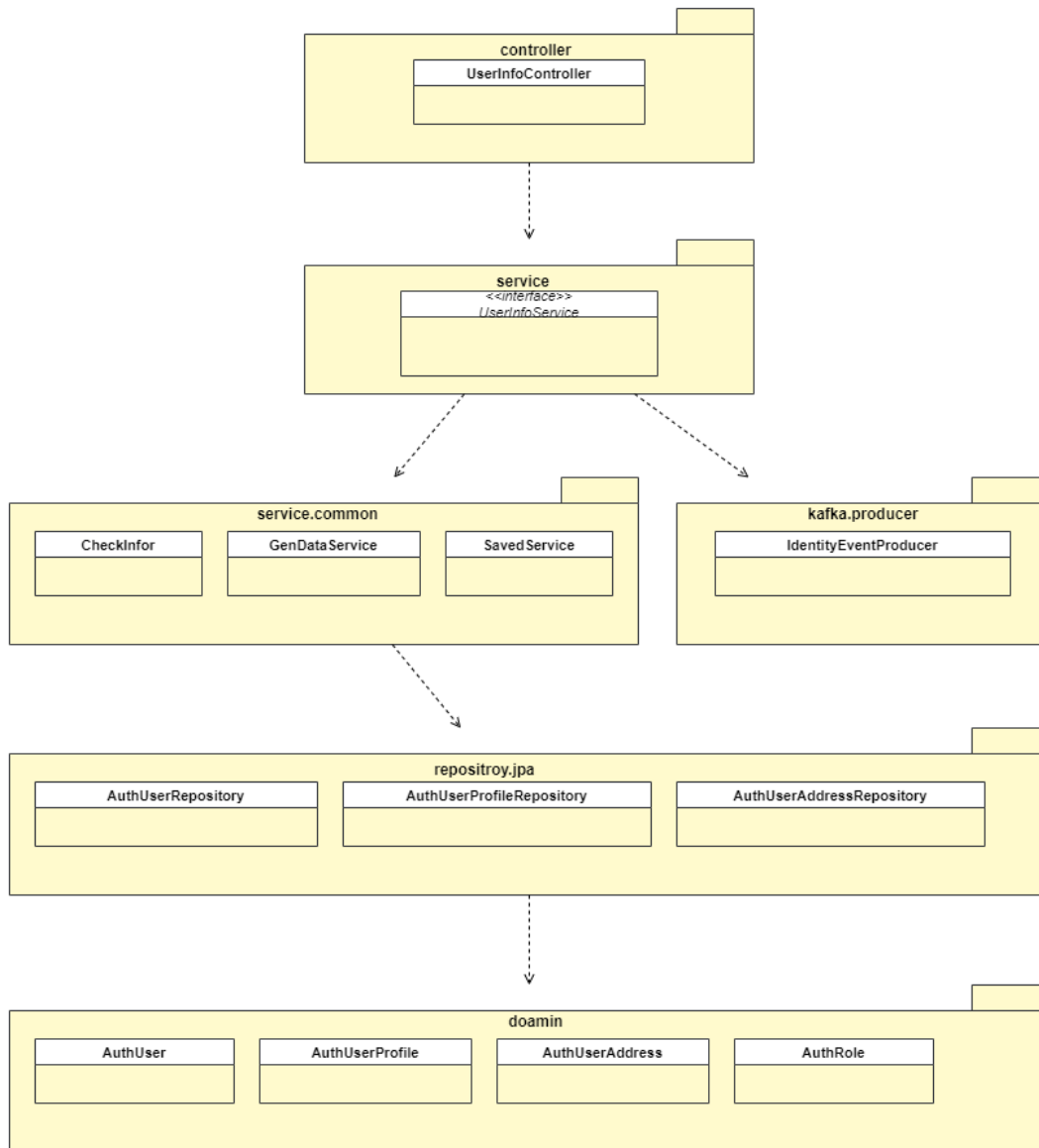
Nguyên tắc phụ thuộc được tuân thủ nhất quán: chiều phụ thuộc chỉ đi từ tầng trên xuống tầng dưới, không có chiều ngược lại; không có gói nào bỏ qua tầng trung gian (*controller* không gọi *repository* trực tiếp); các gói cùng tầng độc lập với nhau (*controller* và *kafka.consumer* đều chỉ gọi *service*, không gọi lẫn nhau).

0.1.3 Thiết kế chi tiết gói

Để làm rõ sự tham gia của từng gói vào các chức năng nghiệp vụ trọng tâm, phần này trình bày biểu đồ gói chi tiết cho bốn luồng xử lý chính của *iam-identity-service*: tạo người dùng mới, yêu cầu và phê duyệt phân quyền, tạm nghỉ và quay trở lại, và luân chuyển vị trí. Mỗi biểu đồ chỉ thể hiện các lớp và giao diện trực tiếp tham gia vào luồng xử lý tương ứng; các lớp hỗ trợ không liên quan đến luồng đó được lược bỏ để giữ sự rõ ràng. Quan hệ giữa các gói trong tất cả biểu đồ đều là quan hệ phụ thuộc (dependency), thể hiện bằng mũi tên nét đứt, với chiều phụ thuộc nhất quán từ tầng trên xuống tầng dưới.

a, Luồng tạo người dùng mới

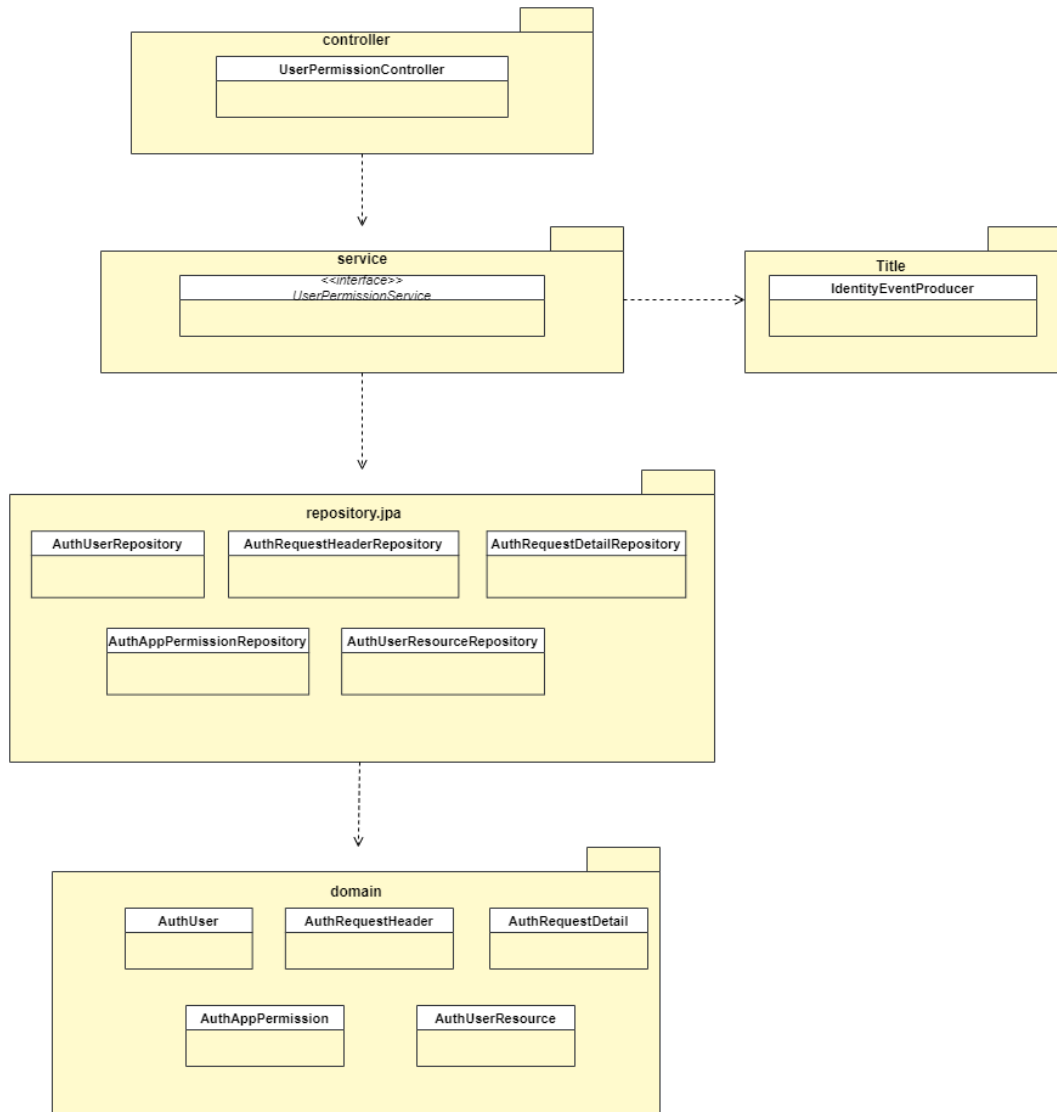
Hình 0.3 trình bày các gói tham gia vào quá trình tạo một tài khoản nhân viên mới. *UserInfoController* tiếp nhận yêu cầu HTTP và ủy thác cho giao diện *UserInfoService*. Tầng nghiệp vụ phối hợp với ba lớp trong *service.common*: *CheckInfo* kiểm tra dữ liệu trùng lặp và tính hợp lệ của địa chỉ, vị trí; *GenDataService* sinh tên đăng nhập và mã nhân viên theo quy tắc nghiệp vụ; *SavedService* lưu toàn bộ thực thể xuống cơ sở dữ liệu trong một giao dịch thống nhất. Sau khi giao dịch thành công, *IdentityEventProducer* phát hai sự kiện Kafka để kích hoạt đồng thời luồng gửi email thông báo và luồng cấp quyền mặc định theo vai trò và vị trí của người dùng.



Hình 0.3: Biểu đồ gói chi tiết — Luồng tạo người dùng mới

b, Luồng yêu cầu và phê duyệt phân quyền

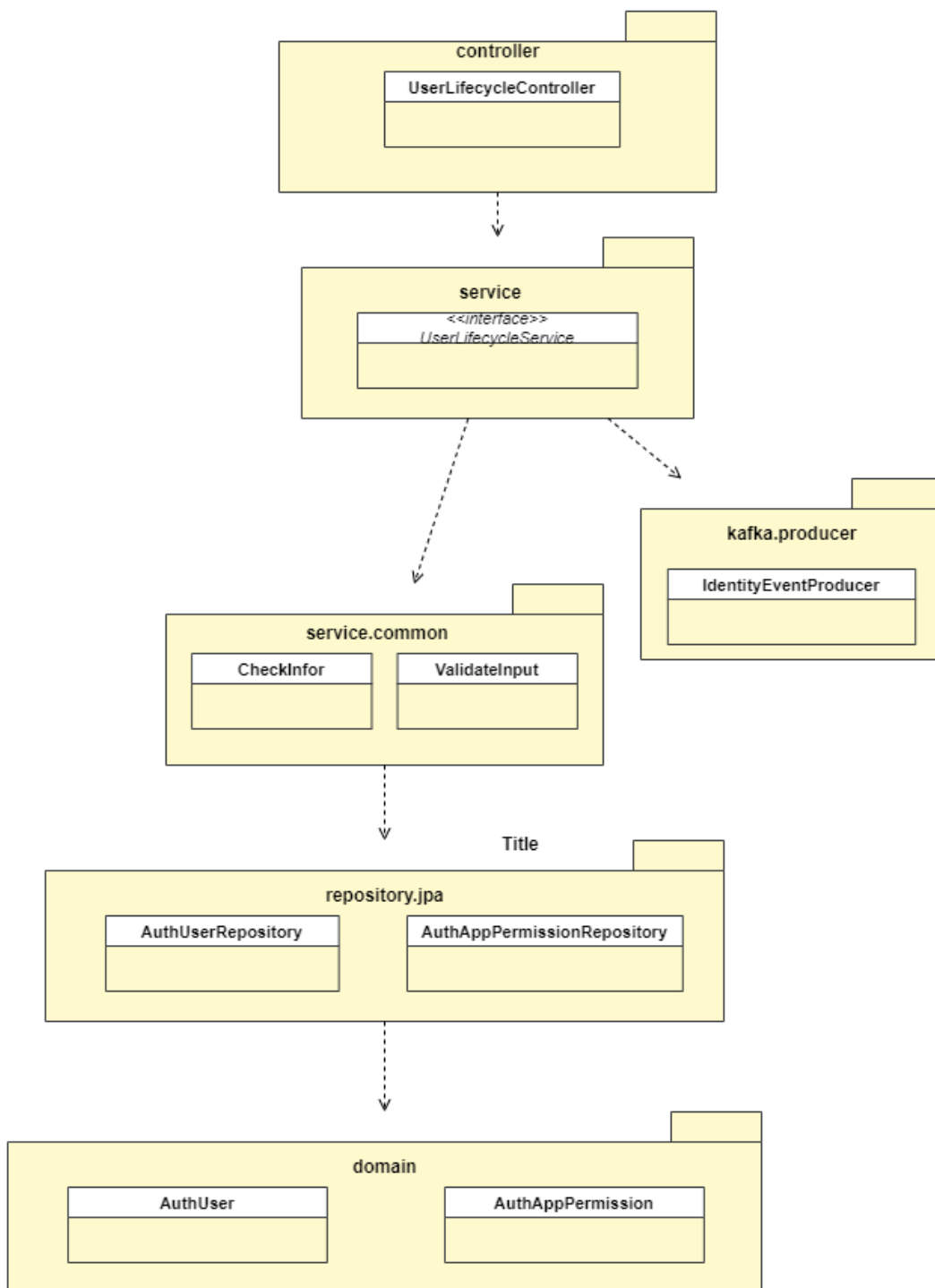
Hình 0.4 mô tả toàn bộ vòng đời của một yêu cầu phân quyền, từ khi nhân viên khởi tạo đến khi CAB phê duyệt và quyền thực sự được cấp. *UserPermissionController* xử lý tất cả các endpoint trong luồng này: tạo yêu cầu nháp, gửi yêu cầu chính thức, và phê duyệt hoặc từ chối. Giao diện *UserPermissionService* điều phối toàn bộ logic. Yêu cầu phân quyền được lưu trữ qua *AuthRequestHeaderRepository* (thông tin tổng quát của yêu cầu) và *AuthRequestDetailRepository* (từng mục quyền cụ thể). Khi CAB phê duyệt, *AuthAppPermissionRepository* và *AuthUserResourceRepository* được cập nhật trực tiếp để hiện thực hóa việc cấp quyền. Mỗi bước chuyển trạng thái đều kích hoạt một sự kiện Kafka thông báo thông qua *IdentityEventProducer*.



Hình 0.4: Biểu đồ gói chi tiết — Luồng yêu cầu và phê duyệt phân quyền

c, Luồng tạm nghỉ và quay trở lại

Hình 0.5 thể hiện luồng nghiệp vụ quản lý trạng thái công tác tạm thời. *UserLifecycleController* xử lý cả hai yêu cầu */leave* (tạm nghỉ) và */return* (quay trở lại), ủy thác cho *UserLifecycleService*. Khi tạm nghỉ, *ValidateInput* kiểm tra tính hợp lệ của khoảng thời gian nghỉ và *CheckInfor* xác nhận người dùng tồn tại hợp lệ; sau đó *AuthAppPermissionRepository* cập nhật trạng thái *SUSPENDED* và gắn mốc thời gian tương ứng. *IdentityEventProducer* phát sự kiện *REVOKED-PERMISSION-NOTIFY* để *iam-auth-service* vô hiệu hóa phiên làm việc ngay lập tức. Khi nhân viên quay trở lại, quyền được khôi phục nguyên trạng mà không cần tạo lại từ đầu và không phát sự kiện Kafka.

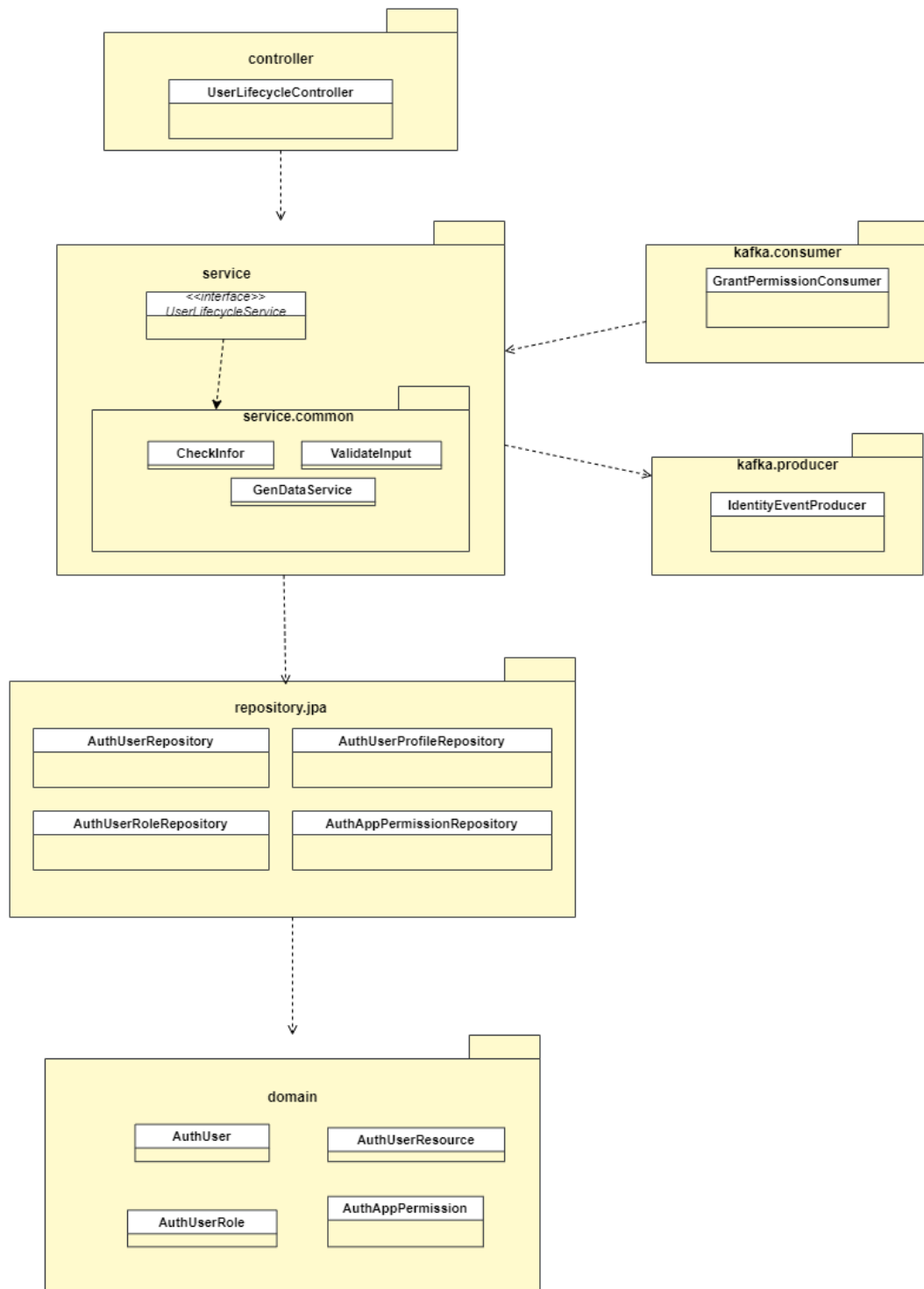


Hình 0.5: Biểu đồ gói chi tiết — Luồng tạm nghỉ và quay trở lại

d, Luồng luân chuyển vị trí

Hình 0.6 trình bày luồng xử lý khi một nhân viên được luân chuyển sang vị trí hoặc phòng ban mới. Đây là luồng có tác động lớn nhất lên dữ liệu phân quyền: *UserLifecycleService* thu hồi toàn bộ vai trò và quyền cũ thông qua *AuthUserRoleRepository*, *AuthAppPermissionRepository*, sau đó gán vai trò mới và cập nhật hồ sơ nhân sự qua *AuthUserProfileRepository*. *CheckInfor* và *ValidateIn-*

put xác thực tính hợp lệ của thông tin đầu vào, còn *GenDataService* hỗ trợ kiểm tra vị trí và phòng ban mới. Sau khi giao dịch hoàn tất, *IdentityEventProducer* phát đồng thời sự kiện REVOKED-PERMISSION-NOTIFY để thu hồi phiên cũ và sự kiện DEFAULT-GRANT-PERMISSION-USER để kích hoạt cấp quyền mặc định theo vị trí mới. Sự kiện thứ hai được *GrantPermissionConsumer* trong gói *kafka.consumer* tiêu thụ ngay trong chính service, thực hiện việc cấp quyền tự động mà không cần thêm bất kỳ lời gọi HTTP nào.



Hình 0.6: Biểu đồ gói chi tiết — Luồng luân chuyển vị trí

0.2 Thiết kế chi tiết

0.2.1 Thiết kế giao diện

a, Đặc tả môi trường hiển thị

Hệ thống IAM Banking Portal hướng đến môi trường trình duyệt web trên máy tính để bàn, phù hợp với điều kiện làm việc của cán bộ ngân hàng tại văn phòng. Độ phân giải mục tiêu là 1440×900 điểm ảnh trở lên; ở mức tối thiểu 1280×768 giao diện vẫn hiển thị đầy đủ chức năng mà không cần cuộn ngang. Màu sắc hỗ trợ 24-bit truecolor (16,7 triệu màu), đảm bảo hiển thị chính xác bảng màu thiết kế. Toàn bộ ứng dụng được xây dựng theo mô hình Single Page Application với Angular 19: các trang thay đổi nội dung mà không tải lại trình duyệt, mang lại trải nghiệm mượt mà tương đương ứng dụng desktop. Màn hình đăng nhập được phục vụ riêng bởi *iam-auth-service* thông qua Thymeleaf template; toàn bộ các màn hình nghiệp vụ còn lại thuộc Angular portal.

b, Hệ màu và kiểu chữ

Giao diện áp dụng bảng màu MB Bank Navy — dải xanh đậm đặc trưng của ngân hàng MB — làm màu chủ đạo, kết hợp nền xám xanh nhạt để tạo tương phản vừa phải, phù hợp khi sử dụng nhiều giờ liên tục. Toàn bộ giá trị màu được khai báo dưới dạng CSS Custom Properties trong *styles.css* toàn cục, cho phép điều chỉnh theme chỉ tại một nơi duy nhất mà không cần can thiệp từng component. Bảng 4 liệt kê các biến màu chính cùng mục đích sử dụng:

Bảng 4: Bảng màu thiết kế IAM Banking Portal

Biến CSS	Giá trị hex	Mục đích
<i>–iam-primary</i>	<i>#003B8E</i>	Màu chủ đạo: header, nút chính, tiêu đề, tab active
<i>–iam-primary-dark</i>	<i>#002868</i>	Trạng thái hover của màu chủ đạo
<i>–iam-body-bg</i>	<i>#F0F4F9</i>	Nền trang (xám xanh nhạt)
<i>–iam-surface</i>	<i>#FFFFFF</i>	Nền card, bảng, modal
<i>–iam-border</i>	<i>#D5E3F5</i>	Viền component, đường kẻ bảng
<i>–iam-text</i>	<i>#0F2044</i>	Văn bản chính (xanh đen đậm)
<i>–iam-text-muted</i>	<i>#5A6E8C</i>	Văn bản phụ, nhãn trường form

Kiểu chữ sử dụng **Inter** (Google Fonts), một typeface sans-serif hiện đại được tối ưu hóa cho màn hình với khả năng đọc tốt ở kích thước nhỏ. Cỡ chữ cơ bản là 0.875rem (14px) với chiều cao dòng 1.6, phù hợp cho giao diện quản trị có mật độ

thông tin cao. Tiêu đề sử dụng font-weight 600–700; nhãn form dùng 500; văn bản phụ dùng 400, tạo hệ thống phân cấp thị giác rõ ràng mà không cần thay đổi màu sắc.

c, Chuẩn hóa thành phần giao diện

Bố cục tổng thể. Mọi màn hình nghiệp vụ đều chia thành ba vùng cố định: header ngang (cao 58px) áp dụng gradient xanh đậm từ #003B8E đến #002060, chứa logo, tên hệ thống và menu người dùng dạng pill ở góc phải; sidebar dọc bên trái áp dụng gradient tối hơn từ #002270 đến #001040, chứa menu điều hướng theo nhóm chức năng có thể thu gọn; vùng nội dung chính chiếm phần còn lại với nền #F0F4F9. Sự phân tầng màu sắc từ tối (sidebar) qua trung bình (header) đến sáng (nội dung) tạo chiều sâu thị giác tự nhiên và định hướng sự chú ý vào nội dung trung tâm.

Nút bấm và hành động. Nút chính (*btn-primary*) dùng màu #003B8E với hiệu ứng nổi nhẹ khi hover (dịch -1px theo trục Y, tăng shadow). Nút phụ (*btn-outline-primary*) dùng viền màu primary trên nền trắng. Bán kính bo góc thống nhất 6px trên toàn bộ nút. Floating Action Button (FAB) là nút tròn đường kính 52px đặt cố định ở góc dưới bên phải, dùng cho thao tác tạo mới — thiết kế này tránh chiếm diện tích trong layout bảng khi dữ liệu nhiều.

Trường nhập liệu. Tất cả *input* và *select* dùng viền #D5E3F5, bo góc 6px. Khi được focus, viền chuyển sang #7BA7D8 với hiệu ứng glow xanh nhạt (box-shadow), phản hồi trực quan tức thì về trường đang được chọn. Nhãn trường (*form-label*) hiển thị chữ in hoa nhỏ màu muted, tách biệt rõ ràng khỏi nội dung nhập. Thanh tìm kiếm (*search-bar*) thêm đường viền trái 3px màu primary, tạo điểm nhấn thị giác phân biệt khu vực lọc khỏi bảng kết quả.

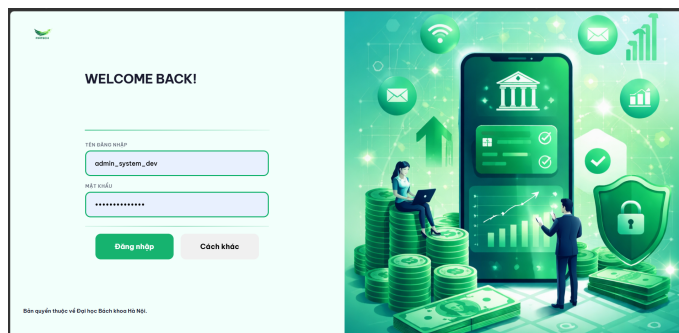
Bảng dữ liệu. Tiêu đề bảng dùng nền gradient xanh rất nhạt, chữ in hoa nhỏ màu primary với letter-spacing 0.05em, tạo sự chuyên nghiệp và dễ phân biệt từng cột. Hàng dữ liệu được tô xen kẽ (striped) và highlight xanh nhạt #ECF3FD khi hover. Thay vì cột hành động riêng, toàn bộ hàng là vùng nhấn được để điều hướng đến trang chi tiết — thiết kế này tăng vùng nhấn và giảm số lượng phần tử thị giác trong bảng.

Badge trạng thái. Mỗi trạng thái nghiệp vụ được biểu diễn bằng badge màu riêng theo ngữ nghĩa quy ước: ACTIVE (xanh lá), PENDING (xanh dương), APPROVED (xanh ngọc), REJECTED (đỏ), REVOKED (cam), INACTIVE/DRAFT (xám). Tất cả badge dùng màu nền nhạt ghép với màu chữ đậm cùng tông, đảm bảo tỷ lệ tương phản đạt chuẩn WCAG AA mà không gây cảm giác chói.

Modal và thông báo phản hồi. Modal dùng overlay nền tối mờ với backdrop-filter blur 2px, panel trắng bo góc 14px và header gradient xanh rất nhạt. Thông báo phản hồi (*alert-floating*) hiển thị cố định ở góc trên bên phải màn hình với hiệu ứng shadow nổi, tự ẩn sau vài giây mà không chặn tương tác bên dưới.

d, Minh họa màn hình thiết kế

Hình 0.7 trình bày màn hình đăng nhập do *iam-auth-service* phục vụ. Thiết kế áp dụng gradient xanh đậm ba lớp ($\#001F52 \rightarrow \#003B8E \rightarrow \#0056C8$) phủ toàn màn hình, kết hợp với hiệu ứng ánh sáng hình cầu mờ ở hai góc để tạo chiều sâu. Card đăng nhập trắng bo góc 20px nổi bật trên nền tối, chứa biểu tượng khóa trong vòng tròn gradient, tên hệ thống và nút đăng nhập qua MB Bank SSO. Thông điệp “Kết nối bảo mật · OAuth2 PKCE” ở chân card thể hiện rõ cơ chế xác thực được áp dụng.



Hình 0.7: Màn hình đăng nhập — IAM Banking Portal

Hình 0.8 minh họa màn hình danh sách người dùng, thể hiện ba thành phần thiết kế quan trọng trong một khung nhìn duy nhất. Phần đầu trang có thanh tìm kiếm với đường viền trái xanh (*search-bar*) chứa năm bộ lọc bao gồm họ tên, tên đăng nhập, mã nhân viên, phòng ban và trạng thái; kết quả lọc cập nhật tức thì khi nhấn tìm kiếm. Bảng dữ liệu phía dưới hiển thị thông tin tóm tắt người dùng với badge trạng thái màu sắc, hàng highlight khi hover và toàn bộ hàng là vùng nhấn để vào chi tiết. FAB xanh dương ở góc dưới bên phải là điểm vào duy nhất để tạo người dùng mới, hiển thị có điều kiện chỉ khi người dùng hiện tại có quyền *user:update* và vai trò ADMIN.

MÃ NV	USERNAME	HỌ TÊN	EMAIL	TRẠNG THÁI
BANK2020000003	ADMINNV	NGUYEN VAN ADMIN	ADMINNV@bank.com.vn	ACTIVE
ERP_SYS_DEV	ADMIN_SYSTEM_DEV	Admin System Dev	admin_dev@bank.local	ACTIVE
BANK2020000006	ANHVD	VŨ ĐÌNH ANH	ANHVD@bank.com.vn	ACTIVE
BANK2020000004	CABNV	NGUYEN VAN CAB	CABNV@bank.com.vn	ACTIVE
BANK2020000009	CUONGNC	NGUYỄN CHÍ CUONG	CUONGNC@bank.com.vn	ACTIVE
BANK2020000010	CUONGNC1	NGUYỄN CHÍ CUONG	CUONGNC1@bank.com.vn	ACTIVE
BANK2020000011	CUONGNC2	NGUYỄN CHÍ CUONG	CUONGNC2@bank.com.vn	ACTIVE
BANK2020000005	CUONGVD	VŨ ĐÌNH CUONG	CUONGVD@bank.com.vn	ACTIVE
BANK2020000007	CUONGVD1	VŨ ĐÌNH CUONG	CUONGVD1@bank.com.vn	ACTIVE
BANK2020000008	CUONGVD2	VŨ ĐÌNH CUONG	CUONGVD2@bank.com.vn	ACTIVE
BANK2020000016	DAINT	NGUYỄN TIẾN ĐẠI	DAINT@bank.com.vn	ACTIVE
BANK2020000020	DANHDD	ĐÀO ĐỨC DANH	DANHDD@bank.com.vn	ACTIVE
BANK2020000012	HABNV	NGUYỄN VĂN HẢI	HABNV@bank.com.vn	ACTIVE

Hình 0.8: Màn hình danh sách người dùng

Hình 0.9 thể hiện màn hình chi tiết và chỉnh sửa thông tin người dùng. Trang này áp dụng mô hình inline editing: thay vì chuyển đổi giữa chế độ xem và chế độ sửa, các trường được hiển thị trực tiếp dưới dạng input khi người dùng có quyền chỉnh sửa. Các trường chỉ đọc và trường có thể chỉnh sửa phân biệt nhau qua nền màu: nền trắng với viền cho trường nhập liệu, nền trong suốt cho giá trị chỉ đọc. Phần “Quyền hiện tại” ở cuối trang chỉ hiển thị khi người xem là ADMIN và không phải đang xem hồ sơ cá nhân của mình, thể hiện nguyên tắc hiển thị có điều kiện theo vai trò.

IAM Banking Portal

AADMIN_SYSTEM_DEV

Quản lý User

Thông tin user

Biến động nhân sự

Phân quyền

Role

Đặt lại mật khẩu

Quản lý cấu hình

Quản lý Users / Thông tin User / Thông tin Chi tiết

← Quay lại

Thông tin Chi tiết User

THÔNG TIN CƠ BẢN

Mã NV

BANK2026000003

Username

ADMINNV

Họ tên

NGUYEN VAN ADMIN

Tên hiển thị

ADMINNV

Ngày sinh

06/15/1985

Giới tính

Nam

Trạng thái

ACTIVE

LIÊN HỆ

Email hệ thống

ADMINNV@bank.com.vn

Email cá nhân

admin_demo@bank.vn

Điện thoại

0901234561

CCCD / CMND

Số CCCD

001085006001

Ngày cấp

01/10/2015

Nơi cấp

Cục Canh Sat QLHC TTXH

THÔNG TIN CÁ NHÂN

Quốc tịch

Viet Nam

Dân tộc

Kinh

Tôn giáo

Không

THÔNG TIN CÔNG VIỆC

Phòng ban

-- Chọn --

Chức vụ

Chuyên viên công nghệ thông tin

Ngày vào làm

01/01/2024

ROLE

MÃ ROLE	TÊN ROLE
ADMIN	Quản trị viên kỹ thuật

ĐỊA CHỈ

LOẠI	TỈNH / THÀNH PHỐ	PHƯỜNG / XÃ	CHI TIẾT
Tạm trú	Thành phố Hà Nội	Xã Mê Linh	123 Nguyen Van Cu
Quê quán	Thành phố Hà Nội	Xã Mê Linh	123 Nguyen Van Cu
Thường trú	Thành phố Hà Nội	Xã Mê Linh	123 Nguyen Van Cu

✓ Lưu thay đổi

↻ Làm mới

🟢 Admin — toàn bộ thông tin

QUYỀN HIỆN TẠI

Quyền ứng dụng 1

Quyền tài nguyên 0

ỨNG DỤNG	MÃ DỊCH VỤ	NGUỒN CẤP	TRẠNG THÁI	THỜI GIAN CẤP
IAM PORTAL	IAN_PORTAL_WEB	ACTIVE	15/05/2026	Thu

16

Hình 0.10 minh họa màn hình quản lý yêu cầu phân quyền — chức năng trung tâm của bài toán phân quyền. Màn hình chia thành ba tab ngang: tab đầu hiển thị danh sách quyền hiện có của nhân viên phân theo hai loại (quyền ứng dụng và quyền tài nguyên) thông qua pill nav; tab thứ hai hiển thị danh sách yêu cầu phân quyền với năm bộ lọc và bảng kết quả có thể nhấn vào từng hàng để xem chi tiết; tab thứ ba dành cho CAB duyệt yêu cầu. FAB xanh dương ở tab danh sách yêu cầu hiển thị label “Tạo yêu cầu” khi hover, điều hướng đến trang tạo yêu cầu đầy đủ. Thiết kế tab phân tầng này cho phép ba nhóm người dùng khác nhau (nhân viên xem quyền, nhân viên tạo yêu cầu, CAB phê duyệt) sử dụng cùng một URL mà không gây nhầm lẫn về luồng thao tác.

#	NGƯỜI DUYỆT	LÝ DO	TRẠNG THÁI	NGÀY TẠO	NGÀY DUYỆT
29	NGUYỄN CHÍ CƯỜNG BANK2026000010	Xin quyền admin	APPROVED	16/06/2026 22:15	16/06/2026 22:15
28	NGUYỄN CHÍ CƯỜNG BANK2026000010	Xin full quyền vào change-app	APPROVED	16/06/2026 21:56	16/06/2026 21:57
19	NGUYỄN CHÍ CƯỜNG BANK2026000010	Xin quyền vào gitlab Đồng ý	APPROVED	07/06/2026 11:43	07/06/2026 11:44
15	NGUYỄN CHÍ CƯỜNG BANK2026000010	Xin full quyền phụ vụ test change amt app Anh đồng ý	APPROVED	03/06/2026 20:32	03/06/2026 20:33
14	NGUYỄN CHÍ CƯỜNG BANK2026000010	Xin quyền vào change-log Anh đồng ý	APPROVED	02/06/2026 23:22	02/06/2026 23:22
13	NGUYỄN CHÍ CƯỜNG BANK2026000010	Cấp quyền vào Change amt Anh đồng ý	APPROVED	02/06/2026 20:36	02/06/2026 20:36
12	NGUYỄN CHÍ CƯỜNG BANK2026000010	Xin quyền vào change App Anh đồng ý	APPROVED	01/06/2026 23:31	01/06/2026 23:32
11	NGUYỄN CHÍ CƯỜNG BANK2026000010	Yêu cầu quyền vào log app hệ thống lam Anh đồng ý	APPROVED	31/05/2026 12:07	31/05/2026 12:08
10	NGUYỄN CHÍ CƯỜNG BANK2026000010	test ko phê duyệt	REJECTED	30/05/2026 22:24	30/05/2026 22:49
9	NGUYỄN CHÍ CƯỜNG BANK2026000010	Test tự chối	REJECTED	30/05/2026 22:23	30/05/2026 22:49

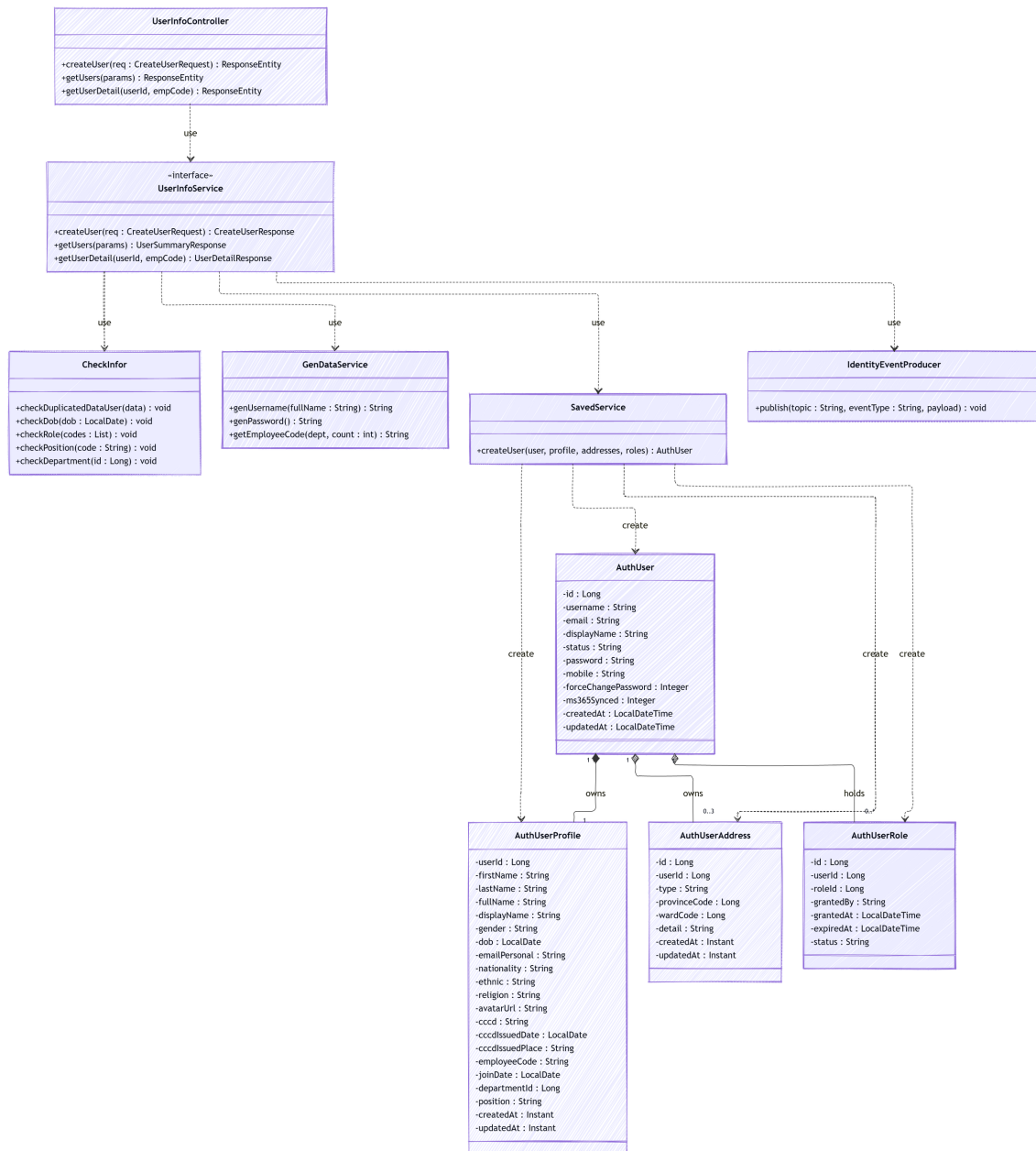
Hình 0.10: Màn hình quản lý yêu cầu phân quyền

0.2.2 Thiết kế lớp

Để làm rõ thiết kế ở mức đối tượng, mục này trình bày biểu đồ lớp và biểu đồ trình tự cho bốn luồng nghiệp vụ trọng tâm đã phân tích trong mục 0.1.3. Biểu đồ lớp tập trung vào các lớp trực tiếp tham gia vào từng luồng, bao gồm controller, service interface, các lớp dùng chung (common services), repository và entity domain; quan hệ phụ thuộc giữa các lớp được biểu diễn bằng mũi tên nét đứt theo quy ước UML. Biểu đồ trình tự minh họa thứ tự truyền thông điệp từ thời điểm người dùng gọi API đến khi hệ thống phản hồi kết quả, kể cả các tương tác bất đồng bộ qua Kafka.

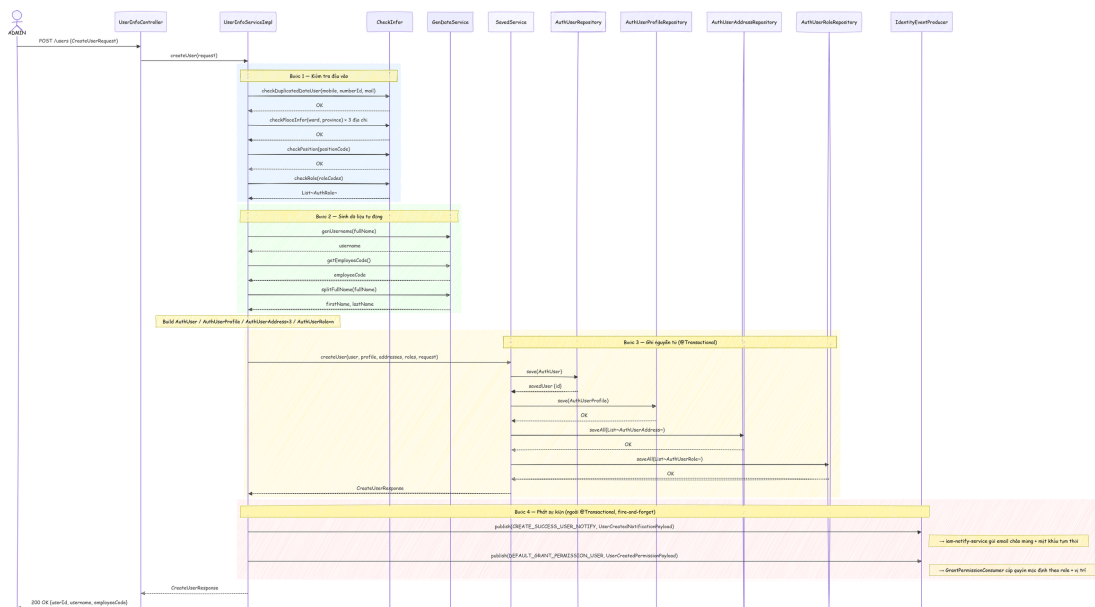
a, Luồng tạo người dùng mới

Hình 0.11 trình bày biểu đồ lớp cho luồng tạo người dùng mới. *UserInfoController* tiếp nhận yêu cầu HTTP và ủy thác toàn bộ logic nghiệp vụ cho *UserInfoService* — service interface trung tâm điều phối ba nhóm xử lý chính. Trước tiên, *CheckInfor* thực hiện chuỗi kiểm tra đầu vào: phát hiện dữ liệu trùng lặp (tên đăng nhập, email, số điện thoại), xác nhận tuổi hợp lệ, kiểm tra vị trí và phòng ban tồn tại trong hệ thống. Tiếp theo, *GenDataService* sinh tự động tên đăng nhập theo quy tắc đặt tên, mật khẩu tạm thời và mã nhân viên. Cuối cùng, *SavedService* đóng gói toàn bộ thao tác ghi vào một đơn vị giao dịch *@Transactional* duy nhất, đảm bảo bốn bảng liên quan — người dùng, hồ sơ, địa chỉ, vai trò — được cập nhật nguyên tử. Sau khi giao dịch thành công, *IdentityEventProducer* phát hai sự kiện Kafka ra ngoài phạm vi giao dịch để thông báo qua email và kích hoạt cấp quyền mặc định.



Hình 0.11: Biểu đồ lớp — Luồng tạo người dùng mới

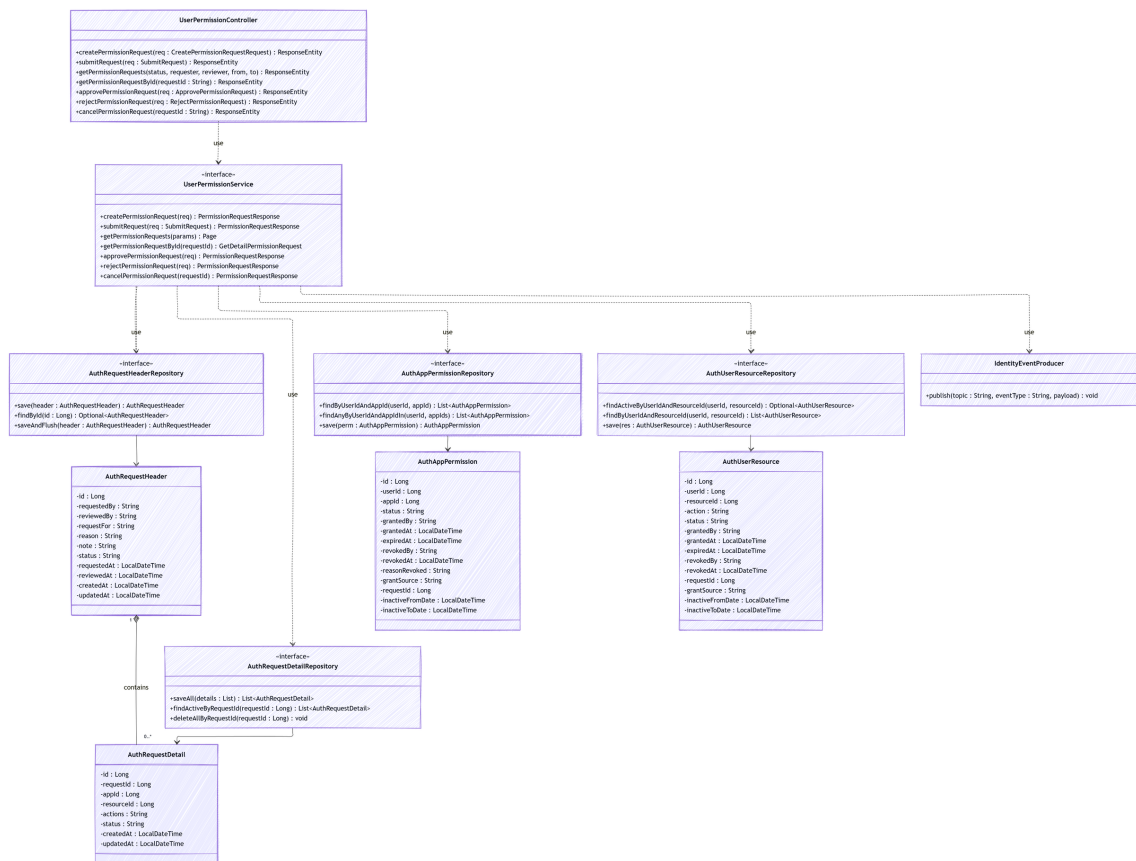
Biểu đồ trình tự tại hình 0.12 thể hiện thứ tự gửi thông điệp giữa các đối tượng trong luồng này. Sau khi Admin gọi *POST /users*, controller chuyển yêu cầu xuống service; service gọi tuần tự *CheckInfor* để kiểm tra toàn bộ điều kiện hợp lệ, sau đó *GenDataService* để sinh dữ liệu, rồi gọi *SavedService* thực hiện ghi nguyên tử qua bốn lần lưu tuần tự vào cơ sở dữ liệu. Điểm quan trọng trong thiết kế là hai lời gọi *IdentityEventProducer* nằm ngoài phạm vi *@Transactional* của *SavedService*: ngay cả khi Kafka tạm thời không khả dụng, dữ liệu người dùng vẫn được bảo toàn trong cơ sở dữ liệu Oracle.



Hình 0.12: Biểu đồ trình tự — Luồng tạo người dùng mới

b, Luồng yêu cầu và phê duyệt phân quyền

Hình 0.13 mô tả thiết kế lớp cho luồng yêu cầu và phê duyệt phân quyền. *UserPermissionController* phục vụ năm endpoint tương ứng với năm thao tác trên vòng đời của một yêu cầu: tạo nhập, gửi chính thức, phê duyệt, từ chối và hủy. Hai entity domain chủ đạo là *AuthRequestHeader* — lưu thông tin phiếu yêu cầu gồm người xin, người duyệt, trạng thái và thời gian — và *AuthRequestDetail* — lưu chi tiết các quyền được xin với trường actions kiểu chuỗi CSV; một phiếu yêu cầu có quan hệ một-nhiều với các dòng chi tiết. *AuthRequestHeaderRepository* dùng *saveAndFlush* thay cho *save* thông thường để lấy ID được sinh ngay lập tức trong cùng giao dịch, phục vụ việc liên kết các bản ghi detail sau đó. *IdentityEventProducer* thông báo cho người duyệt khi có yêu cầu mới và thông báo kết quả khi yêu cầu được xử lý.



Hình 0.13: Biểu đồ lớp — Luồng yêu cầu và phê duyệt phân quyền

Biểu đồ trình tự tại hình 0.14 chia luồng thành ba giai đoạn. Giai đoạn một: nhân viên tạo yêu cầu ở trạng thái *DRAFT* hoặc *OFFICIAL*; service kiểm tra tính hợp lệ của người duyệt (phải có vai trò CAB và trạng thái ACTIVE) cùng các tài nguyên được xin (phải tồn tại và đang hoạt động) trước khi lưu vào cơ sở dữ liệu. Giai đoạn hai: nhân viên gửi chính thức yêu cầu đang ở trạng thái *DRAFT* thông qua endpoint */submit*; hệ thống chuyển trạng thái sang *OFFICIAL* và gửi thông báo Kafka đến người duyệt. Giai đoạn ba: CAB phê duyệt; service thực hiện cấp quyền thực sự — ghi vào *AUTH_APP_PERMISSION* (bỏ qua nếu đã tồn tại) và merge actions vào *AUTH_USER_RESOURCE* (union với actions hiện có) — trong một giao dịch duy nhất, sau đó phát sự kiện thông báo kết quả.

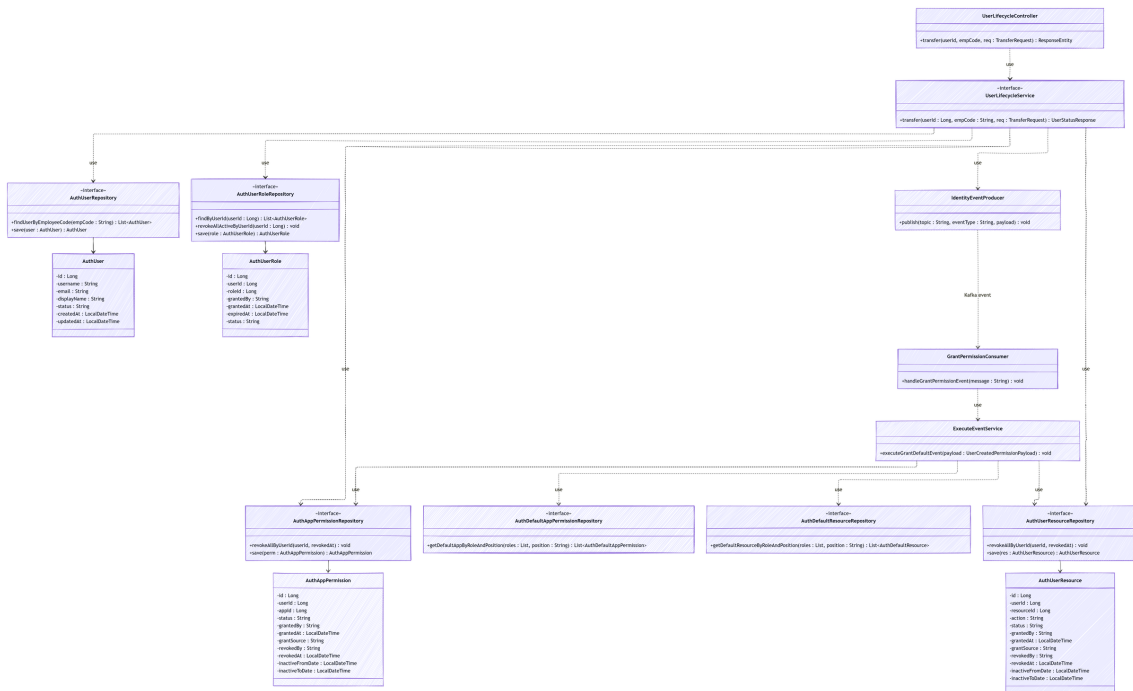


Biểu đồ trình tự tại hình 0.16 chia thành hai khung màu phân biệt. Luồng tạm nghỉ: sau khi *ValidateInput* kiểm tra khoảng thời gian và *CheckInfor* xác nhận người dùng, service gọi *setInactiveDates* để ghi nhãn thời gian rồi phát sự kiện Kafka thu hồi phiên đăng nhập hiện tại. Luồng quay trở lại: service chỉ cần xác nhận người dùng tồn tại rồi gọi *clearInactiveDates* để xóa nhãn tạm nghỉ mà không cần phát sự kiện Kafka, vì *iam-auth-service* sẽ tự kiểm tra ngày hiệu lực khi nhân viên thực hiện đăng nhập lại.

Hình 0.16: Biểu đồ trình tự — Luồng tam nghỉ và quay trở lại

d, Luồng luân chuyển vị trí

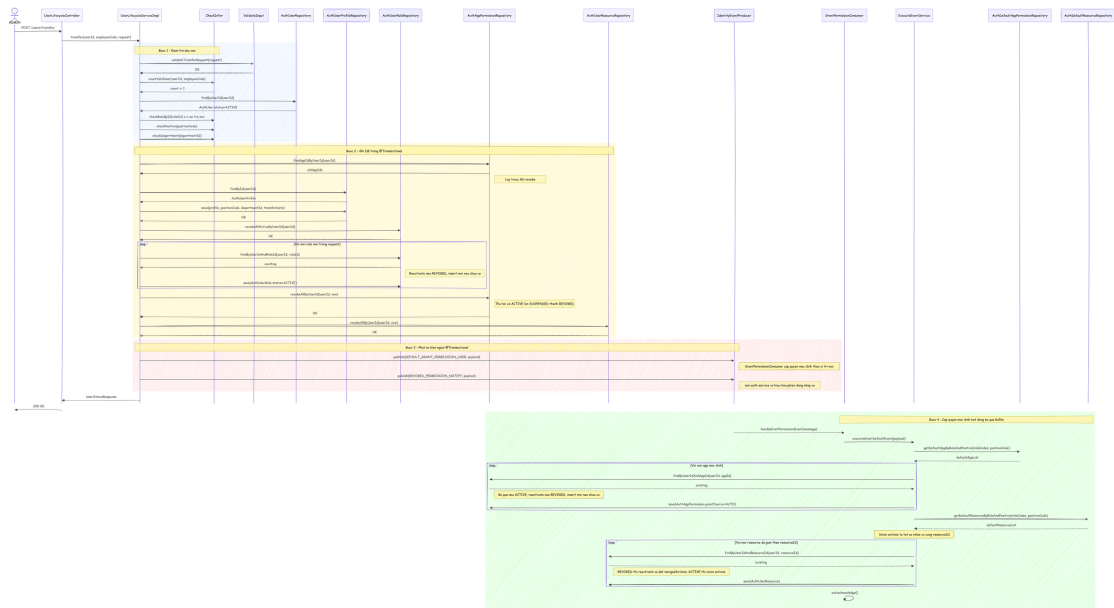
Hình 0.17 trình bày thiết kế lớp cho luồng luân chuyển vị trí — luồng có tác động phân quyền lớn nhất trong hệ thống. *UserLifecycleService* phụ thuộc đồng thời vào ba repository: *AuthUserRoleRepository* để thu hồi toàn bộ vai trò cũ và gán vai trò mới, *AuthAppPermissionRepository* để thu hồi quyền ứng dụng cũ, và *AuthUserResourceRepository* để thu hồi quyền tài nguyên cũ; ba thao tác thu hồi và một thao tác gán vai trò mới được bao bởi cùng một giao dịch. Sau khi giao dịch kết thúc, *IdentityEventProducer* phát đồng thời hai sự kiện Kafka độc lập: sự kiện *REVOKED_PERMISSION_NOTIFY* để *iam-auth-service* vô hiệu hóa phiên đăng nhập cũ ngay lập tức, và sự kiện *DEFAULT_GRANT_PERMISSION* để kích hoạt cấp quyền theo vị trí mới. Sự kiện thứ hai được *GrantPermissionConsumer* — Kafka consumer nội bộ trong cùng service — tiêu thụ và ủy thác cho *ExecuteEventService* thực hiện cấp quyền mặc định theo ma trận vị trí.



Hình 0.17: Biểu đồ lớp — Luồng luân chuyển vị trí

Biểu đồ trình tự tại hình 0.18 thể hiện rõ đặc điểm bất đồng bộ của luồng: sau khi giao dịch chính hoàn tất và hai sự kiện Kafka được phát ra, *GrantPermissionConsumer* nhận sự kiện *DEFAULT_GRANT_PERMISSION* và gọi *ExecuteEventService* để tự động cấp quyền mặc định cho vị trí mới mà không cần thêm bất kỳ lời gọi HTTP nào từ phía người dùng. *ExecuteEventService* áp dụng hai cơ chế chống trùng lặp: với quyền ứng dụng, dùng *HashSet* để loại bỏ trùng lặp kể cả trong cùng một batch; với quyền tài nguyên, thực hiện union actions từ nhiều vai trò nếu cùng tài nguyên để đảm bảo tính nhất quán dữ liệu ngay cả khi nhân viên được gán nhiều

vai trò có tài nguyên chung.



Hình 0.18: Biểu đồ trình tự — Luồng luân chuyển vị trí

0.2.3 Thiết kế cơ sở dữ liệu

Hệ thống IAM sử dụng Oracle Database với schema AUTH_USER1 làm nền tảng lưu trữ dữ liệu dùng chung cho toàn bộ các microservice. Tổng cộng 28 bảng được tổ chức theo ba cụm chức năng chính, phản ánh ba miền nghiệp vụ cốt lõi: cụm người dùng, cụm phân quyền, và cụm cấu hình ứng dụng. Hình 0.19 mô tả sơ đồ thực thể liên kết toàn hệ thống với đầy đủ các mối quan hệ giữa các thực thể.

Bảng 6: Cấu trúc bảng AUTH_USER_PROFILE

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
USER_ID	NUMBER	Khóa chính	Quan hệ 1-1 với AUTH_USER
FIRST_NAME	VARCHAR2(100)		Họ
LAST_NAME	VARCHAR2(100)		Tên
FULL_NAME	VARCHAR2(200)		Họ và tên đầy đủ
DISPLAY_NAME	VARCHAR2(200)		Tên hiển thị do người dùng tự chỉnh
GENDER	VARCHAR2(10)		Giới tính
DOB	DATE		Ngày sinh
EMAIL_PERSONAL	VARCHAR2(200)		Email cá nhân (dùng nhận thông báo)
CCCD	VARCHAR2(20)		Số căn cước công dân
CCCD_ISSUED_DATE	DATE		Ngày cấp CCCD
CCCD_ISSUED_PLACE	VARCHAR2(200)		Nơi cấp CCCD
EMPLOYEE_CODE	VARCHAR2(50)		Mã nhân viên nội bộ
JOIN_DATE	DATE		Ngày vào làm việc
DEPARTMENT_ID	NUMBER		Phòng ban đang công tác
POSITION	VARCHAR2(200)		Mã chức danh
AVATAR_URL	VARCHAR2(500)		Đường dẫn ảnh đại diện
CREATED_AT	TIMESTAMP(6)	NOT NULL	Thời điểm tạo
UPDATED_AT	TIMESTAMP(6)	NOT NULL	Thời điểm cập nhật

Bảng 7: Cấu trúc bảng AUTH_USER_ADDRESS

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_USER_ADDRESS
USER_ID	NUMBER	NOT NULL	Người dùng sở hữu địa chỉ
TYPE	VARCHAR2(10)	NOT NULL, CHECK	Loại địa chỉ: PERMANENT / TEMPORARY / BIRTH
PROVINCE_CODE	NUMBER		Tỉnh / thành phố
WARD_CODE	NUMBER		Phường / xã
DETAIL	VARCHAR2(500)		Số nhà, đường, tổ dân phố
CREATED_AT	TIMESTAMP(6)	NOT NULL	Thời điểm tạo
UPDATED_AT	TIMESTAMP(6)	NOT NULL	Thời điểm cập nhật
<i>Ràng buộc UNIQUE: (USER_ID, TYPE) — mỗi người dùng tối đa một địa chỉ mỗi loại</i>			

Bảng 8: Cấu trúc bảng AUTH_DEPARTMENT

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_DEPARTMENT
CODE	VARCHAR2(50)		Mã phòng ban viết tắt
NAME	VARCHAR2(200)	NOT NULL	Tên phòng ban đầy đủ
PARENT_ID	NUMBER		Phòng ban cha; NULL nếu là gốc (cấu trúc cây đệ quy)
STATUS	NUMBER(1)		1 = đang hoạt động, 0 = đã giải thể
CREATED_AT	TIMESTAMP(6)		Thời điểm tạo
UPDATED_AT	TIMESTAMP(6)		Thời điểm cập nhật

Bảng 9: Cấu trúc bảng AUTH_POSITION

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
CODE	VARCHAR2(50)	Khóa chính	Mã chức danh (VD: DEV, TESTER, BA)
NAME	VARCHAR2(200)	NOT NULL	Tên chức danh đầy đủ
DESCRIPTION	VARCHAR2(500)		Mô tả nhiệm vụ
STATUS	VARCHAR2(20)		ACTIVE / INACTIVE
CREATED_AT	TIMESTAMP(6)		Thời điểm tạo
UPDATED_AT	TIMESTAMP(6)		Thời điểm cập nhật

Bảng 10: Cấu trúc bảng AUTH_ROLE

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_ROLE
CODE	VARCHAR2(50)	UNIQUE	Mã vai trò: STAFF / CAB / ADMIN
NAME	VARCHAR2(200)		Tên vai trò đầy đủ
DESCRIPTION	VARCHAR2(500)		Mô tả phạm vi quyền hạn
CREATED_AT	TIMESTAMP(6)		Thời điểm tạo

Bảng 11: Cấu trúc bảng AUTH_USER_ROLE

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_USER_ROLE
USER_ID	NUMBER	NOT NULL	Người dùng được gán vai trò
ROLE_ID	NUMBER	NOT NULL	Vai trò được gán
GRANTED_BY	VARCHAR2(100)		Mã nhân viên người thực hiện gán
GRANTED_AT	TIMESTAMP(6)		Thời điểm gán vai trò
EXPIRED_AT	TIMESTAMP(6)		Thời điểm hết hạn; NULL = vô thời hạn
STATUS	VARCHAR2(20)		ACTIVE / REVOKED

Bảng 12: Cấu trúc bảng AUTH_PROVINCE

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
CODE	NUMBER	Khóa chính	Mã hành chính tỉnh / thành phố
NAME	VARCHAR2(200)	NOT NULL	Tên tỉnh / thành phố
DIVISION_TYPE	VARCHAR2(50)	NOT NULL	Loại đơn vị: tỉnh, thành phố trực thuộc trung ương
CODENAME	VARCHAR2(200)	NOT NULL	Tên viết tắt không dấu
PHONE_CODE	NUMBER		Mã vùng điện thoại
STATUS	VARCHAR2(10)	NOT NULL, CHECK	ACTIVE / INACTIVE

Bảng 13: Cấu trúc bảng AUTH_WARD

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
CODE	NUMBER	Khóa chính	Mã hành chính phường / xã / thị trấn
NAME	VARCHAR2(200)	NOT NULL	Tên đơn vị hành chính
DIVISION_TYPE	VARCHAR2(50)	NOT NULL	Loại: phường, xã, thị trấn
CODENAME	VARCHAR2(200)	NOT NULL	Tên không dấu
PROVINCE_CODE	NUMBER	NOT NULL	Tỉnh / thành phố trực thuộc
STATUS	VARCHAR2(10)	NOT NULL, CHECK	ACTIVE / INACTIVE

b, Cụm thông tin phân quyền

Cụm phân quyền là trung tâm nghiệp vụ của hệ thống, gồm bảy bảng lưu trữ cấu hình tài nguyên, quyền thực tế của người dùng, quyền mặc định theo vai trò và chức danh, cùng luồng phê duyệt quyền theo quy trình CAB.

Bảng 14: Cấu trúc bảng AUTH_RESOURCE

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_RESOURCE
APP_ID	NUMBER	NOT NULL	Ứng dụng sở hữu tài nguyên
RESOURCE_CODE	VARCHAR2(100)	NOT NULL	Mã tài nguyên (VD: user, orders, reports)
RESOURCE_NAME	VARCHAR2(200)		Tên mô tả tài nguyên
RESOURCE_TYPE	VARCHAR2(50)		Loại tài nguyên (API, FUNCTION, DATA...)
ACTIONS	VARCHAR2(500)		Danh sách hành động hỗ trợ, phân cách bằng dấu phẩy
LDAP_GROUP_NAME	VARCHAR2(200)		Tên nhóm LDAP ánh xạ tương ứng
DESCRIPTION	VARCHAR2(500)		Mô tả tài nguyên
STATUS	VARCHAR2(20)		ACTIVE / INACTIVE
CREATED_AT	TIMESTAMP(6)		Thời điểm tạo

Bảng 15: Cấu trúc bảng AUTH_APP_PERMISSION

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_APP_PERMISSION
USER_ID	NUMBER	NOT NULL	Người dùng được cấp quyền
APP_ID	NUMBER	NOT NULL	Ứng dụng được phép truy cập
STATUS	VARCHAR2(20)	NOT NULL	ACTIVE / INACTIVE / REVOKED
GRANTED_BY	VARCHAR2(100)		Mã nhân viên người cấp quyền
GRANTED_AT	TIMESTAMP(6)		Thời điểm cấp quyền
EXPIRED_AT	TIMESTAMP(6)		Thời điểm hết hạn; NULL = vô hạn
REVOKED_BY	VARCHAR2(100)		Mã nhân viên người thu hồi
REVOKED_AT	TIMESTAMP(6)		Thời điểm thu hồi
REASON_REVOKED	VARCHAR2(500)		Lý do thu hồi quyền
GRANT_SOURCE	VARCHAR2(50)		Nguồn cấp: default (tự động) / request (CAB duyệt)
REQUEST_ID	NUMBER		Yêu cầu phê duyệt tương ứng
INACTIVE_FROM_DATE	TIMESTAMP(6)		Bắt đầu tạm hoãn quyền (nghỉ phép)
INACTIVE_TO_DATE	TIMESTAMP(6)		Kết thúc tạm hoãn quyền

Bảng 16: Cấu trúc bảng AUTH_USER_RESOURCE

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_USER_RESOURCE
USER_ID	NUMBER		Người dùng được cấp quyền
RESOURCE_ID	NUMBER		Tài nguyên được cấp
ACTION	VARCHAR2(500)		Danh sách hành động được phép (CSV); 1 dòng cho mỗi cấp user-resource
STATUS	VARCHAR2(20)		ACTIVE / INACTIVE / REVOKED
GRANTED_BY	VARCHAR2(100)		Mã nhân viên người cấp
GRANTED_AT	TIMESTAMP(6)		Thời điểm cấp
EXPIRED_AT	TIMESTAMP(6)		Thời điểm hết hạn
REVOKED_BY	VARCHAR2(100)		Mã nhân viên người thu hồi
REVOKED_AT	TIMESTAMP(6)		Thời điểm thu hồi
REQUEST_ID	NUMBER		Yêu cầu CAB tương ứng
GRANT_SOURCE	VARCHAR2(50)		default / request
INACTIVE_FROM_DATE	TIMESTAMP(6)		Bắt đầu tạm hoãn
INACTIVE_TO_DATE	TIMESTAMP(6)		Kết thúc tạm hoãn

Bảng 17: Cấu trúc bảng AUTH_DEFAULT_APP_PERMISSION

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_DEFAULT_APP_PERMISSION
ROLE_ID	VARCHAR2(50)	NOT NULL	Mã vai trò (STAFF / CAB / ADMIN)
POSITION_CODE	VARCHAR2(50)		Mã chức danh áp dụng
APPLICATION_ID	NUMBER		Ứng dụng được cấp mặc định
STATUS	VARCHAR2(20)		ACTIVE / INACTIVE
CREATED_BY	VARCHAR2(100)		Mã nhân viên người cấu hình
CREATED_AT	TIMESTAMP(6)		Thời điểm tạo
UPDATED_AT	TIMESTAMP(6)		Thời điểm cập nhật
Ràng buộc UNIQUE: (ROLE_ID, POSITION_CODE, APPLICATION_ID)			

Bảng 18: Cấu trúc bảng AUTH_DEFAULT_RESOURCE

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_DEFAULT_RESOURCE
ROLE_ID	NUMBER	NOT NULL	ID vai trò (kiểu số, khác AUTH_DEFAULT_APP_PERMISSION dùng mã)
POSITION_CODE	VARCHAR2(50)		Mã chức danh áp dụng
RESOURCE_ID	NUMBER		Tài nguyên được cấp mặc định
ACTIONS	VARCHAR2(500)		Tập con hành động từ AUTH_RESOURCE.ACTIONS (CSV)
STATUS	VARCHAR2(20)		ACTIVE / INACTIVE
CREATED_BY	VARCHAR2(100)		Mã nhân viên người cấu hình
CREATED_AT	TIMESTAMP(6)		Thời điểm tạo
UPDATED_AT	TIMESTAMP(6)		Thời điểm cập nhật
Ràng buộc UNIQUE: (ROLE_ID, POSITION_CODE, RESOURCE_ID)			

Bảng 19: Cấu trúc bảng AUTH_REQUEST_HEADER

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_REQUEST_HEADER
REQUESTED_BY	VARCHAR2(100)		Mã nhân viên người tạo yêu cầu
REVIEWED_BY	VARCHAR2(100)		Mã nhân viên CAB được chỉ định duyệt
REQUEST_FOR	VARCHAR2(100)		Mã nhân viên được cấp quyền
REASON	VARCHAR2(1000)		Lý do yêu cầu cấp quyền
NOTE	VARCHAR2(1000)		Ghi chú khi duyệt hoặc từ chối
STATUS	VARCHAR2(20)		DRAFT / OFFICIAL / APPROVED / REJECTED / CANCELLED
REQUESTED_AT	TIMESTAMP(6)		Thời điểm gửi yêu cầu chính thức
REVIEWED_AT	TIMESTAMP(6)		Thời điểm CAB thực hiện phê duyệt
CREATED_AT	TIMESTAMP(6)	NOT NULL	Thời điểm tạo bản nháp
UPDATED_AT	TIMESTAMP(6)	NOT NULL	Thời điểm cập nhật

Bảng 20: Cấu trúc bảng AUTH_REQUEST_DETAIL

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_REQUEST_DETAIL
REQUEST_ID	NUMBER	NOT NULL	Phiếu yêu cầu chứa chi tiết này
APP_ID	NUMBER		Ứng dụng được yêu cầu quyền truy cập
RESOURCE_ID	NUMBER		Tài nguyên cụ thể (NULL nếu chỉ yêu cầu quyền app)
ACTIONS	VARCHAR2(500)		Hành động được yêu cầu trên tài nguyên (CSV)
STATUS	VARCHAR2(20)		ACTIVE / INACTIVE
CREATED_AT	TIMESTAMP(6)	NOT NULL	Thời điểm tạo
UPDATED_AT	TIMESTAMP(6)	NOT NULL	Thời điểm cập nhật

c, Cụm thông tin ứng dụng

Cụm này gồm tám bảng định nghĩa cấu hình đầy đủ của các ứng dụng đăng ký trên hệ thống IAM: thông tin ứng dụng, cấu hình OAuth2 client, các phương thức xác thực được kích hoạt, và cây luồng xác thực đa bước.

Bảng 21: Cấu trúc bảng AUTH_CLIENT_GROUP

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	ID nhóm ứng dụng
NAME	VARCHAR2(200)	NOT NULL	Tên nhóm (VD: Ngân hàng lõi, Nội bộ)
DESCRIPTION	VARCHAR2(500)		Mô tả nhóm
CREATED_AT	TIMESTAMP(6)		Thời điểm tạo
UPDATED_AT	TIMESTAMP(6)		Thời điểm cập nhật

Bảng 22: Cấu trúc bảng AUTH_APPLICATION

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_APPLICATION
NAME	VARCHAR2(200)	NOT NULL	Tên ứng dụng
DESCRIPTION	VARCHAR2(500)		Mô tả mục đích ứng dụng
APP_TYPE	VARCHAR2(50)		INTERNAL / THIRD_PARTY_LDAP
LOGO_URI	VARCHAR2(500)		Đường dẫn logo
DEFAULT_URL	VARCHAR2(500)		URL trang chủ ứng dụng
STATUS	VARCHAR2(20)		ACTIVE / INACTIVE
SERVICE_CODE	VARCHAR2(100)	UNIQUE	Mã định danh service trong chuỗi phân quyền (VD: iam-service)
DEPARTMENT_ID	NUMBER		Phòng ban chủ quản
GROUP_ID	NUMBER		Nhóm ứng dụng
ACR_LEVEL	NUMBER		Mức độ xác thực tối thiểu yêu cầu (ACR)
CREATED_AT	TIMESTAMP(6)	NOT NULL	Thời điểm tạo
UPDATED_AT	TIMESTAMP(6)	NOT NULL	Thời điểm cập nhật

Bảng 23: Cấu trúc bảng AUTH_CLIENT

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_CLIENT
CLIENT_ID	VARCHAR2(200)	UNIQUE	Chuỗi định danh OAuth2 gửi trong request
CLIENT_SECRET	VARCHAR2(500)		Mật khẩu client đã mã hóa BCrypt; NULL với public client
NAME	VARCHAR2(200)		Tên mô tả client
CLIENT_TYPE	VARCHAR2(20)		public / confidential
DEFAULT_URL	VARCHAR2(500)		URL chuyển hướng mặc định
ENABLED	NUMBER(1)		1 = đang hoạt động, 0 = vô hiệu hóa
APP_ID	NUMBER	NOT NULL	Ứng dụng sở hữu client
CREATED_AT	TIMESTAMP(6)		Thời điểm tạo
UPDATED_AT	TIMESTAMP(6)		Thời điểm cập nhật

Bảng 24: Cấu trúc bảng AUTH_CLIENT_OAUTH

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_CLIENT_OAUTH
CLIENT_ID	NUMBER	NOT NULL	Quan hệ 1-1 với AUTH_CLIENT
GRANT_TYPES	VARCHAR2(500)		Grant type CSV (authorization_code, client_credentials...)
REDIRECT_URI	VARCHAR2(1000)		Danh sách redirect URI hợp lệ
ALLOWED_SCOPES	VARCHAR2(500)		Scopes được phép, phân cách bằng dấu cách
ACCESS_TOKEN_TTL	NUMBER		Thời gian sống access token (giây)
REFRESH_TOKEN_TTL	NUMBER		Thời gian sống refresh token (giây)
ID_TOKEN_TTL	NUMBER		Thời gian sống ID token (giây)
TOKEN_ENDPOINT	VARCHAR2(50)		Phương thức xác thực tại token endpoint
REQUIRE_PKCE	NUMBER(1)		1 = bắt buộc PKCE (Proof Key for Code Exchange)
REQUIRE_CONSENT	NUMBER(1)		1 = hiển thị màn hình đồng ý
POST_LOGOUT_REDIRECT_URI	VARCHAR2(500)		URL chuyển hướng sau đăng xuất
CREATED_AT	TIMESTAMP(6)		Thời điểm tạo
UPDATED_AT	TIMESTAMP(6)		Thời điểm cập nhật

Bảng 25: Cấu trúc bảng AUTH_METHOD

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_METHOD
METHOD	VARCHAR2(100)	UNIQUE	Tên phương thức: USERNAME_PASSWORD / OTP_EMAIL / TOTP
STATUS	NUMBER(1)		1 = hệ thống hỗ trợ, 0 = tạm tắt
CREATED_AT	TIMESTAMP(6)		Thời điểm tạo
UPDATED_AT	TIMESTAMP(6)		Thời điểm cập nhật

Bảng 26: Cấu trúc bảng AUTH_CLIENT_METHOD

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_CLIENT_METHOD
APP_ID	NUMBER	NOT NULL	Ứng dụng kích hoạt phương thức này
METHOD_ID	NUMBER	NOT NULL	Phương thức xác thực được kích hoạt
CONFIG	VARCHAR2(2000)		Cấu hình JSON đặc thù từng phương thức (maxLoginAttempts, otpLength, otpExpirySeconds...)
STATUS	VARCHAR2(20)		ACTIVE / INACTIVE
CREATED_AT	TIMESTAMP(6)		Thời điểm tạo
UPDATED_AT	TIMESTAMP(6)		Thời điểm cập nhật

Bảng 27: Cấu trúc bảng AUTH_FLOW

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_FLOW
APP_ID	NUMBER	NOT NULL	Ứng dụng sở hữu luồng xác thực
ALIAS	VARCHAR2(100)	UNIQUE per APP_ID	Tên định danh luồng, duy nhất trong mỗi ứng dụng
DESCRIPTION	VARCHAR2(500)		Mô tả luồng xác thực
IS_BUILT_IN	NUMBER(1)		1 = luồng hệ thống, không được vô hiệu hóa
STATUS	VARCHAR2(20)		ACTIVE / INACTIVE; mỗi ứng dụng chỉ có tối đa một luồng ACTIVE
CREATED_AT	TIMESTAMP(6)		Thời điểm tạo
UPDATED_AT	TIMESTAMP(6)		Thời điểm cập nhật

Bảng 28: Cấu trúc bảng AUTH_FLOW_EXECUTION

Tên trường	Kiểu dữ liệu	Ràng buộc	Mô tả
ID	NUMBER	Khóa chính	Sinh tự động bởi SEQ_AUTH_FLOW_EXECUTION
FLOW_ID	NUMBER	NOT NULL	Luồng xác thực chứa node này
PARENT_NODE_ID	NUMBER		Node cha; NULL nếu là node gốc (tự tham chiếu)
CLIENT_METHOD	NUMBER	NOT NULL	Phương thức xác thực ứng với node này
REQUIREMENT	VARCHAR2(20)	CHECK	REQUIRED / OPTIONAL / ALTERNATIVE / DISABLED
IS_DEFAULT	NUMBER(1)		1 = node mặc định trong nhóm sibling
STATUS	VARCHAR2(20)		ACTIVE / INACTIVE
CREATED_AT	TIMESTAMP(6)		Thời điểm tạo
UPDATED_AT	TIMESTAMP(6)		Thời điểm cập nhật

0.3 Xây dựng ứng dụng

0.3.1 Thư viện và công cụ sử dụng

Quá trình thiết kế và xây dựng hệ thống IAM sử dụng một tập hợp các framework, thư viện và công cụ hỗ trợ trải dài trên bốn nhóm chức năng: phát triển backend, phát triển frontend, hỗ trợ vận hành và tích hợp trí tuệ nhân tạo. Bảng 29 tổng hợp toàn bộ danh sách cùng phiên bản sử dụng.

Bảng 29: Danh sách công cụ và thư viện sử dụng

Tên công cụ / thư viện	Mục đích sử dụng	Phiên bản
<i>Framework và thư viện backend</i>		
Spring Boot	Framework nền tảng cho các microservice Java (iam-auth, iam-identity, iam-app, iam-gateway)	3.2.x / 3.5.x
Spring Security & OAuth2	Bảo mật, triển khai Authorization Server chuẩn OAuth2 / OIDC, JWT resource server	6.x
Spring Cloud Gateway	API Gateway: xác thực token, kiểm tra quyền, chuyển tiếp request tới service	4.x
Spring Data JPA	ORM kết nối Oracle Database, ánh xạ entity — bảng, validate schema	3.x
Oracle Database	Hệ quản trị cơ sở dữ liệu quan hệ lưu toàn bộ dữ liệu IAM (schema AUTH_USER1)	19c
Redis	Lưu authorization code (TTL 60s), quản lý phiên xác thực và cache token	7.x
Apache Kafka	Message broker xử lý sự kiện bất đồng bộ giữa các microservice	3.x (KRaft)
Lombok	Tự động sinh getter / setter / builder, giảm boilerplate code	1.18.x
MapStruct	Ánh xạ tự động giữa DTO và entity tại thời điểm biên dịch	1.5.x
<i>Framework và thư viện frontend</i>		
Angular	Framework SPA xây dựng IAM Admin Portal (iam-web-service)	19
Angular (demo app)	Framework SPA xây dựng giao diện ứng dụng demo Change Management	17
TypeScript	Ngôn ngữ lập trình chính phía frontend, kiểm tra kiểu tĩnh	5.x
Bootstrap Icons	Bộ icon sử dụng xuyên suốt giao diện quản trị	1.x
<i>Công cụ phát triển và vận hành</i>		
Visual Studio Code	IDE phát triển Angular, soạn thảo LaTeX	1.x
IntelliJ IDEA	IDE phát triển Java Spring Boot	2024.x
Postman	Kiểm thử API thủ công, soạn collection test	11.x
Docker & Docker Compose	Đóng gói microservice thành container, quản lý môi trường tích hợp	27.x
draw.io	Vẽ sơ đồ kiến trúc, ERD, sequence diagram	Web (app.diagrams.net)
DBeaver	Công cụ truy vấn và quản lý Oracle Database	24.x
Git	Quản lý phiên bản mã nguồn	2.x
<i>Công cụ trí tuệ nhân tạo hỗ trợ</i>		
Claude Code	Hỗ trợ viết code, thiết kế kiến trúc hệ thống và soạn thảo tài liệu đề án	Sonnet 4.6
ChatGPT	Hỗ trợ tra cứu kỹ thuật, giải thích lỗi và đề xuất giải pháp	GPT-4o

0.3.2 Kết quả đạt được

Hệ thống IAM được tổ chức theo kiến trúc microservice, chia thành hai nhóm thành phần chính: backend gồm năm service độc lập viết bằng Java/Spring Boot, và frontend gồm hai ứng dụng Angular đảm nhận vai trò giao diện quản trị và ứng dụng demo nghiệp vụ. Toàn bộ mã nguồn được phát triển trên môi trường Windows

11, quản lý phiên bản bằng Git.

Các tác nhân trong hệ thống. Hệ thống phân quyền phục vụ ba nhóm người dùng với vai trò và quyền hạn khác nhau. Nhân viên (STAFF) là tác nhân phổ biến nhất, đại diện cho lập trình viên và nhân viên ngân hàng sử dụng các ứng dụng nội bộ hàng ngày; họ có thể gửi yêu cầu cấp quyền truy cập ứng dụng hoặc tài nguyên thông qua luồng phê duyệt CAB. Thành viên Hội đồng Tư vấn Thay đổi (CAB) là người được chỉ định xem xét và phê duyệt hoặc từ chối các yêu cầu đó; vai trò này đảm bảo mọi thay đổi về quyền đều có sự kiểm soát độc lập trước khi áp dụng. Quản trị viên IAM (ADMIN) nắm quyền quản lý toàn bộ hệ thống: tạo tài khoản, gán vai trò, cấu hình ứng dụng, tài nguyên, luồng xác thực và quyền mặc định; đây là tác nhân duy nhất có thể thu hồi quyền tức thì mà không cần qua luồng phê duyệt.

Thông kê mã nguồn. Bảng 30 trình bày số liệu thống kê về từng thành phần của hệ thống, bao gồm ngôn ngữ lập trình chính, môi trường phát triển và số dòng mã nguồn (tính trên các tệp .java, .ts, .html, .css, .xml, .yaml).

Bảng 30: Thông kê mã nguồn từng thành phần hệ thống

Thành phần	Loại	Ngôn ngữ chính	Môi trường	Số dòng
iam-auth-service	Backend	Java 21, Spring Boot 3.5	Windows 11	≈8 100
iam-identity-service	Backend	Java 21, Spring Boot 3.2	Windows 11	≈7 700
iam-app-service	Backend	Java 21, Spring Boot 3.2	Windows 11	≈6 500
iam-gateway	Backend	Java 21, Spring Boot 3.2	Windows 11	≈770
iam-notify-service	Backend	Java 21, Spring Boot 3.2	Windows 11	≈1 260
iam-web-service	Frontend	TypeScript, Angular 19	Windows 11	≈10 200
demo-change-app	Full-stack	Java 21 + TypeScript, Angular 17	Windows 11	≈8 800
Tổng cộng				≈43 330

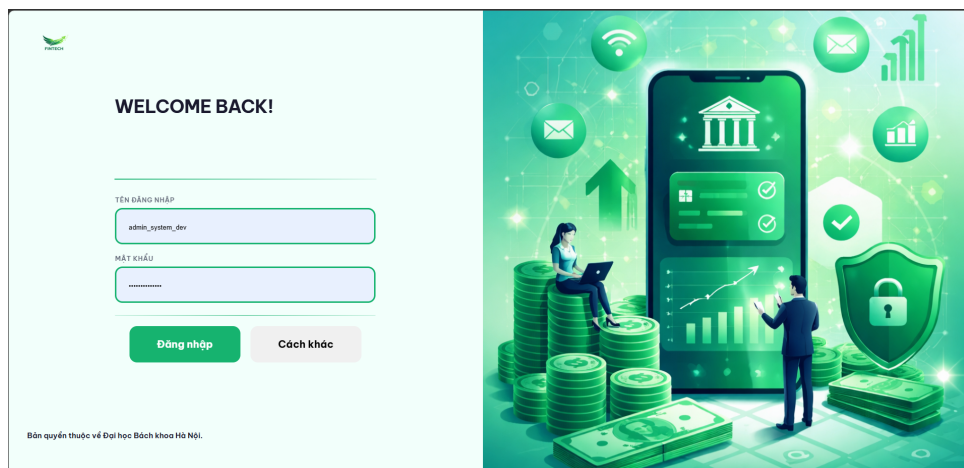
Toàn bộ hệ thống đạt xấp xỉ 43 000 dòng mã nguồn, phân bổ đều giữa các service backend và hai ứng dụng frontend. Service `iam-auth-service` có số dòng lớn nhất do phải triển khai toàn bộ engine xác thực OAuth2/OIDC, quản lý phiên và ký token bằng ES256; trong khi `iam-gateway` nhỏ gọn nhất vì chỉ đảm nhận ba bộ lọc trung chuyển chính. Kết quả này cho thấy việc tách biệt rõ trách nhiệm giữa các service đã được thực hiện tốt, giúp mỗi thành phần tập trung vào một miền nghiệp vụ cụ thể và dễ dàng bảo trì độc lập.

0.3.3 Minh họa các chức năng chính

Phần này trình bày giao diện minh họa cho các use case quan trọng nhất của hệ thống, được tổ chức theo từng nhóm tác nhân. Mỗi màn hình phản ánh một bước cụ thể trong vòng đời phân quyền, từ xác thực đăng nhập đến cấp phát, phê duyệt và thu hồi quyền.

a, Xác thực và đăng nhập

Hệ thống sử dụng luồng OAuth2 Authorization Code với PKCE để xác thực người dùng. Khi truy cập cổng quản trị, người dùng được chuyển hướng về trang đăng nhập do iam-auth-service phục vụ. Sau khi nhập thông tin hợp lệ, hệ thống hoàn tất các bước xác thực đa yếu tố (nếu được cấu hình) rồi cấp phát token và chuyển người dùng về ứng dụng.



Hình 0.20: Trang đăng nhập — luồng OAuth2 PKCE qua iam-auth-service

b, Giao diện quản trị viên (ADMIN)

Quản trị viên IAM có quyền truy cập đầy đủ vào tất cả các chức năng quản lý. Hình 0.21 thể hiện màn hình danh sách người dùng với bộ lọc đa chiều (họ tên, username, mã nhân viên, phòng ban, trạng thái), cho phép ADMIN tra cứu nhanh bất kỳ tài khoản nào trong hệ thống.

MÃ NV	USERNAME	HỌ TÊN	EMAIL	TRẠNG THÁI
BANK2826000003	ADMINV	NGUYEN VAN ADMIN	ADMINV@bank.com.vn	ACTIVE
EMP_SYS_DEV	ADMIN_SYSTEM_DEV	Admin System Dev	admin_dev@bank.local	ACTIVE
BANK2826000006	ANHVD	VŨ ĐÌNH ANH	ANHVD@bank.com.vn	ACTIVE
BANK2826000004	CABNV	NGUYEN VAN CAB	CABNV@bank.com.vn	ACTIVE
BANK2826000009	CUONGNC	NGUYEN CHI CUONG	CUONGNC@bank.com.vn	ACTIVE
BANK2826000010	CUONGNC1	NGUYEN CHI CUONG	CUONGNC1@bank.com.vn	ACTIVE
BANK2826000011	CUONGNC2	NGUYEN CHI CUONG	CUONGNC2@bank.com.vn	ACTIVE
BANK2826000005	CUONGVD	VŨ ĐÌNH CUONG	CUONGVD@bank.com.vn	ACTIVE
BANK2826000007	CUONGVD1	VŨ ĐÌNH CUONG	CUONGVD1@bank.com.vn	ACTIVE
BANK2826000008	CUONGVD2	VŨ ĐÌNH CUONG	CUONGVD2@bank.com.vn	ACTIVE
BANK2826000016	DAINT	NGUYEN TIEN DAI	DAINT@bank.com.vn	ACTIVE
BANK2826000020	DANHDD	ĐÀO ĐỨC DANH	DANHDD@bank.com.vn	ACTIVE
BANK2826000019	HAINV	NGUYEN VAN HAI	HAINV@bank.com.vn	ACTIVE

Hình 0.21: Danh sách người dùng với bộ lọc đa chiều (ADMIN)

Khi chọn một người dùng cụ thể, ADMIN được chuyển đến trang chi tiết (Hình 0.22) hiển thị đầy đủ thông tin hồ sơ, địa chỉ và danh sách quyền hiện tại. Tại đây, ADMIN có thể chỉnh sửa thông tin hoặc thu hồi từng quyền ứng dụng và quyền tài nguyên cụ thể.

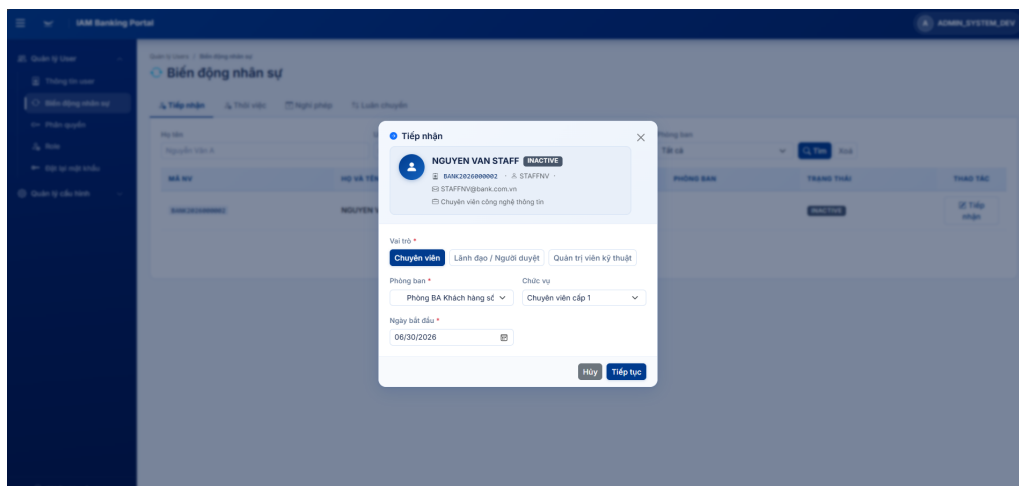
LOẠI	TỈNH / THÀNH PHỐ	PHƯỜNG / XÃ	CHI TIẾT
Thường trú	Thành phố Hà Nội	Xã Phúc Lộc	12 phúc lộc
Tạm trú	Thành phố Hà Nội	Xã Phúc Lộc	12 phúc lộc
Quê quán	Thành phố Hà Nội	Xã Phúc Lộc	12 phúc lộc

ỨNG DỤNG	MÃ DỊCH VỤ	NGUỒN CẤP	TRẠNG THÁI	THỜI GIAN CẤP	
IAM Internal System	iam-service		ACTIVE	12/06/2026	Thu hồi
Gitlab Server	gitlab-server		ACTIVE	12/06/2026	Thu hồi
Change & Go-Live Management	change-regat		ACTIVE	12/06/2026	Thu hồi
Log Application	log-app-service		ACTIVE	12/06/2026	Thu hồi

Hình 0.22: Chi tiết người dùng — mục quyền hiện tại và nút thu hồi (ADMIN)

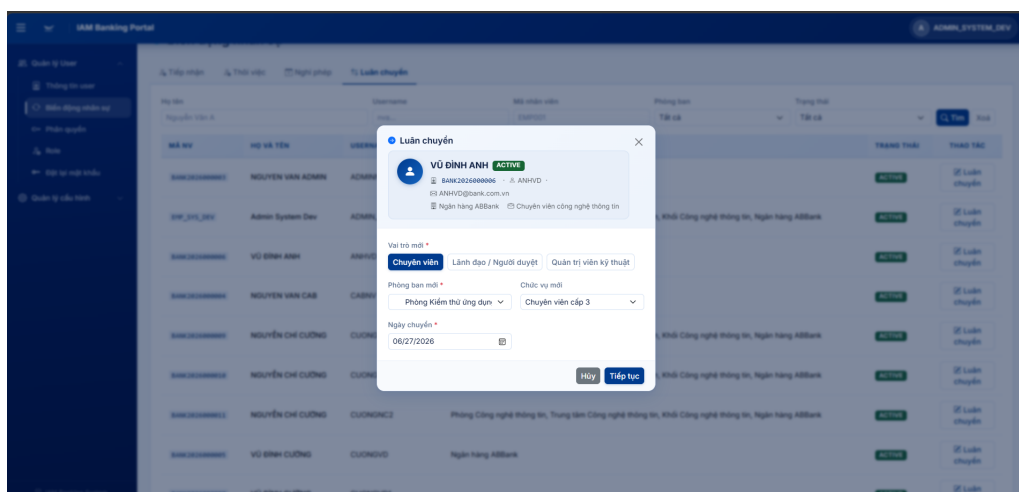
c, Quản lý vòng đời nhân sự (ADMIN)

Chức năng biến động nhân sự hỗ trợ bốn nghiệp vụ: tiếp nhận (onboard), thôi việc (offboard), nghỉ phép và luân chuyển. Hình 0.23 minh họa màn hình tiếp nhận nhân viên mới, trong đó ADMIN chọn vai trò (hỗ trợ chọn đa vai trò), chức danh và xác nhận. Sau khi tiếp nhận, hệ thống tự động cấp quyền mặc định tương ứng với vai trò và chức danh thông qua sự kiện Kafka.



Hình 0.23: Tiếp nhận nhân viên mới — chọn vai trò và chức danh (ADMIN)

Hình 0.24 thể hiện nghiệp vụ luân chuyển, trong đó ADMIN cập nhật phòng ban, vai trò và chức danh mới cho nhân viên. Hệ thống tự động thu hồi quyền mặc định cũ và cấp lại quyền mặc định phù hợp với vị trí mới.



Hình 0.24: Luân chuyển nhân viên — cập nhật vai trò và tự động cấp lại quyền mặc định

d, Cấu hình hệ thống (ADMIN)

ADMIN có thể cấu hình toàn bộ thông tin ứng dụng, tài nguyên và quyền mặc định thông qua cổng quản trị. Hình 0.25 minh họa màn hình quản lý quyền mặc định theo vai trò: mỗi dòng tương ứng một cặp (vai trò, chức danh, ứng dụng) và ADMIN bật/tắt trực tiếp bằng công tắc hình viên thuốc (pill toggle) mà không cần thao tác lưu thêm.

ROLE	CHỨC DANH	ỨNG DỤNG	TRẠNG THÁI
Quản trị viên kỹ thuật ADMIN	Trưởng phòng IT TP	Gitlab Server	☒
Quản trị viên kỹ thuật ADMIN	Trưởng nhóm TN	Gitlab Server	☒
Quản trị viên kỹ thuật ADMIN	Chuyên gia CG	Gitlab Server	☒
Quản trị viên kỹ thuật ADMIN	Chuyên viên cao cấp CVCC	Gitlab Server	☒
Quản trị viên kỹ thuật ADMIN	Chuyên viên cấp 3 CV3	Gitlab Server	☒
Quản trị viên kỹ thuật ADMIN	Chuyên viên cấp 2 CV2	Gitlab Server	☒
Quản trị viên kỹ thuật ADMIN	Chuyên viên cấp 1 CV1	Gitlab Server	☒
Chuyên viên STAFF	Chuyên viên cao cấp CVCC	Log-Application	☒
Chuyên viên STAFF	Chuyên gia CG	Log-Application	☒

Hình 0.25: Cấu hình quyền mặc định theo vai trò và chức danh (ADMIN)

e, Gửi yêu cầu phân quyền (STAFF)

Nhân viên (STAFF) có thể chủ động gửi yêu cầu cấp quyền truy cập ứng dụng hoặc tài nguyên cụ thể. Hình 0.26 minh họa form tạo yêu cầu: người dùng chọn người duyệt (CAB), điền lý do, chọn ứng dụng và tài nguyên kèm hành động được yêu cầu. Yêu cầu có thể lưu nháp (DRAFT) hoặc gửi chính thức (OFFICIAL) để bắt đầu luồng phê duyệt.

Username: Mã nhân viên:

Người duyệt (CAB): Mã nhân viên người duyệt:

Lý do yêu cầu:

Quyền ứng dụng:

Quyền tài nguyên:

Ứng dụng: Tài nguyên: Actions:

Buttons:

Hình 0.26: Tạo yêu cầu phân quyền — chọn ứng dụng, tài nguyên và hành động (STAFF)

Sau khi gửi, STAFF theo dõi trạng thái yêu cầu qua danh sách phiếu (Hình 0.27). Danh sách hỗ trợ lọc theo mã nhân viên yêu cầu, người duyệt, trạng thái và khoảng thời gian.

#	NGƯỜI DUYỆT	LÝ DO	TRẠNG THÁI	NGÀY TẠO	NGÀY DUYỆT
29	NGUYỄN CHÍ CƯỜNG BANK2026000010	Xin quyền admin	APPROVED	16/06/2026 22:15	16/06/2026 22:15
28	NGUYỄN CHÍ CƯỜNG BANK2026000010	Xin full quyền vào change-app	APPROVED	16/06/2026 21:56	16/06/2026 21:57
19	NGUYỄN CHÍ CƯỜNG BANK2026000010	Xin quyền vào gitlab Bằng ý	APPROVED	07/06/2026 11:43	07/06/2026 11:44
15	NGUYỄN CHÍ CƯỜNG BANK2026000010	Xin full quyền phụ vụ test change amt app Anh đồng ý	APPROVED	03/06/2026 20:32	03/06/2026 20:33
14	NGUYỄN CHÍ CƯỜNG BANK2026000010	Xin quyền vào change-log Anh đồng ý	APPROVED	02/06/2026 23:22	02/06/2026 23:22
13	NGUYỄN CHÍ CƯỜNG BANK2026000010	Cấp quyền vào Change amt Anh đồng ý	APPROVED	02/06/2026 20:36	02/06/2026 20:36
12	NGUYỄN CHÍ CƯỜNG BANK2026000010	Xin quyền vào change App Anh đồng ý	APPROVED	01/06/2026 23:31	01/06/2026 23:32
11	NGUYỄN CHÍ CƯỜNG BANK2026000010	Yêu cầu quyền vào log app hệ thống lam Anh đồng ý	APPROVED	31/05/2026 12:07	31/05/2026 12:08
10	NGUYỄN CHÍ CƯỜNG BANK2026000010	test ko phê duyệt	REJECTED	30/05/2026 22:24	30/05/2026 22:49
9	NGUYỄN CHÍ CƯỜNG BANK2026000010	Test từ chối	REJECTED	30/05/2026 22:23	30/05/2026 22:49

Hình 0.27: Danh sách yêu cầu phân quyền — theo dõi trạng thái (STAFF)

f, Phê duyệt yêu cầu phân quyền (CAB)

Thành viên CAB nhận thông báo qua email khi có yêu cầu mới cần xem xét. Hình 0.28 thể hiện màn hình chi tiết phiếu yêu cầu, hiển thị đầy đủ thông tin người yêu cầu, người được cấp quyền, lý do, danh sách ứng dụng và tài nguyên kèm hành động. CAB có thể phê duyệt hoặc từ chối kèm ghi chú ngay trên cùng giao diện.

Hình 0.28: Chi tiết yêu cầu phân quyền — phê duyệt hoặc từ chối (CAB)

Sau khi CAB phê duyệt, hệ thống tự động ghi nhận quyền vào AUTH_APP_PERMISSION và AUTH_USER_RESOURCE, đồng thời gửi thông báo email đến người yêu cầu và phát sự kiện Kafka để cập nhật token ngay lần đăng nhập tiếp theo.

0.4 Kiểm thử

Hệ thống được kiểm thử theo kỹ thuật kiểm thử hộp đen (black-box testing), tập trung vào hành vi đầu ra của hệ thống khi nhận các đầu vào khác nhau mà không

cần biết cấu trúc bên trong. Phương pháp này phù hợp để xác minh rằng các luồng nghiệp vụ chính — từ tạo tài khoản đến cấp phát và phê duyệt quyền — hoạt động đúng với đặc tả.

0.4.1 Kiểm thử chức năng tạo người dùng mới

Bảng 31: Các trường hợp kiểm thử chức năng tạo người dùng

Tên trường hợp	Các bước thực hiện	Kỳ vọng	Thực tế	Trạng thái
Tạo người dùng hợp lệ	1. Đăng nhập ADMIN 2. Vào Quản lý User 3. Nhấn nút tạo mới 4. Điền đầy đủ thông tin hợp lệ 5. Nhấn Tạo	Hệ thống tạo tài khoản, hiển thị thông báo thành công, chuyển về danh sách	Tài khoản được tạo thành công, thông báo hiển thị, redirect đúng trang	Pass
Tạo người dùng với username đã tồn tại	1. Đăng nhập ADMIN 2. Vào Quản lý User 3. Nhấn nút tạo mới 4. Nhập username đã có trong hệ thống 5. Nhấn Tạo	Hệ thống từ chối, hiển thị thông báo lỗi username đã tồn tại	Hệ thống trả lỗi trùng username, thông báo hiển thị đúng	Pass
Tạo người dùng thiếu trường bắt buộc	1. Đăng nhập ADMIN 2. Vào Quản lý User 3. Nhấn nút tạo mới 4. Để trống username hoặc mật khẩu 5. Nhấn Tạo	Form ngăn gửi, hiển thị cảnh báo thiếu thông tin bắt buộc	Form validate thất bại, không gửi request lên server, cảnh báo hiển thị đúng	Pass

0.4.2 Kiểm thử chức năng yêu cầu và phê duyệt phân quyền

Bảng 32: Các trường hợp kiểm thử chức năng tạo yêu cầu phân quyền

Tên trường hợp	Các bước thực hiện	Kỳ vọng	Thực tế	Trạng thái
Tạo yêu cầu phân quyền thành công	1. Đăng nhập STAFF 2. Vào Phân quyền, chọn Tạo yêu cầu 3. Chọn người duyệt (CAB) 4. Chọn ứng dụng và tài nguyên 5. Điền lý do 6. Nhấn Gửi	Phiếu lưu trạng thái OFFICIAL, CAB nhận email thông báo	Phiếu OFFICIAL tạo thành công, email gửi đến CAB đúng nội dung	Pass
Tạo yêu cầu thiếu thông tin bắt buộc	1. Đăng nhập STAFF 2. Vào Phân quyền, chọn Tạo yêu cầu 3. Bỏ trống người duyệt hoặc lý do 4. Nhấn Gửi	Form báo lỗi thiếu thông tin, không gửi request	Form validate thất bại, hiển thị cảnh báo đúng trường còn thiếu	Pass

Bảng 33: Các trường hợp kiểm thử chức năng phê duyệt và từ chối của CAB

Tên trường hợp	Các bước thực hiện	Kỳ vọng	Thực tế	Trạng thái
CAB phê duyệt yêu cầu	1. Đăng nhập CAB 2. Vào Phân quyền, mục Duyệt yêu cầu 3. Chọn phiếu trạng thái OFFICIAL 4. Xem chi tiết yêu cầu 5. Nhấn Phê duyệt và xác nhận	Phiếu chuyển APPROVED, quyền được cấp cho người dùng, email thông báo được gửi	Phiếu AP-PROVED thành công, quyền ghi nhận vào cơ sở dữ liệu, email gửi đúng	Pass
CAB từ chối yêu cầu	1. Đăng nhập CAB 2. Vào Phân quyền, mục Duyệt yêu cầu 3. Chọn phiếu trạng thái OFFICIAL 4. Nhấn Từ chối 5. Nhập lý do từ chối 6. Xác nhận	Phiếu chuyển REJECTED, không cấp quyền, email từ chối gửi đến người yêu cầu	Phiếu RE-JECTED thành công, không có quyền nào được cấp, email thông báo từ chối gửi đúng người	Pass

Tổng cộng, bảy trường hợp kiểm thử đã được thiết kế và thực thi cho hai chức năng nghiệp vụ trọng tâm. Tất cả bảy trường hợp đều đạt kết quả Pass, xác nhận rằng hệ thống xử lý đúng cả luồng hợp lệ lẫn các tình huống đầu vào không đầy đủ hoặc dữ liệu trùng lặp. Đặc biệt, luồng phê duyệt CAB hoạt động nhất quán với thiết kế: quyền chỉ được ghi nhận vào cơ sở dữ liệu sau khi có quyết định phê duyệt rõ ràng, và email thông báo được phát đi trong cả hai tình huống chấp thuận và từ chối.

0.5 Triển khai

Hệ thống được triển khai thử nghiệm cục bộ trên máy tính cá nhân chạy Windows 11, sử dụng Docker và Docker Compose để đóng gói và quản lý toàn bộ các thành phần. Môi trường này không kết nối Internet mà hoạt động hoàn toàn trong mạng nội bộ máy, phù hợp cho giai đoạn phát triển và kiểm thử tích hợp.

0.5.1 Mô hình triển khai

Tất cả các service và thành phần hạ tầng được khởi động thông qua Docker Compose với nhiều file overlay, mỗi file quản lý một nhóm thành phần riêng biệt. Các container giao tiếp với nhau qua một mạng bridge nội bộ có tên `iam-internal-network` do Docker tạo và quản lý. Từ máy host, người dùng truy cập hệ thống qua các cổng được ánh xạ ra ngoài như mô tả trong Bảng 34.

Bảng 34: Danh sách container và cổng triển khai cục bộ

Container	Cổng (host)	Vai trò
<i>Hạ tầng</i>		
kafka-1, kafka-2, kafka-3	19092 – 19094	Cụm Kafka 3 broker, chế độ KRaft, xác thực SASL/PLAIN
redis	6379	Cache authorization code, session và token
<i>Microservice IAM</i>		
iam-auth-service	8888	OAuth2 Authorization Server, OIDC IdP, engine xác thực
iam-identity-service	8081	Quản lý người dùng, vai trò, vòng đời nhân sự, phân quyền
iam-app-service	8082	Quản lý ứng dụng, tài nguyên, OAuth2 client, auth flow
iam-gateway	8080	API Gateway — xác thực JWT, kiểm tra quyền, chuyển tiếp request
iam-notify-service	8083	Kafka consumer, gửi email thông báo qua Gmail SMTP
<i>Ứng dụng</i>		
demo-change-app	8085	Ứng dụng demo Change Management (Angular + Spring Boot, 1 image)

0.5.2 Cấu hình môi trường

Mỗi service được đóng gói thành Docker image riêng bằng Dockerfile đặt tại thư mục gốc của từng service. Các biến môi trường (URL kết nối Oracle, thông tin Kafka, Redis, khóa JWT) được truyền vào container qua file `docker-compose` overlay tương ứng, không nhúng cứng vào image. Oracle Database 19c chạy ngoài Docker trên máy host và được các service kết nối qua địa chỉ `host.docker.internal`, đảm bảo dữ liệu không bị mất khi container được tạo lại.

Quy trình khởi động toàn bộ hệ thống được thực hiện theo hai bước: trước tiên khởi động hạ tầng (Kafka cluster và Redis) bằng lệnh `docker compose up -d` với các file overlay tương ứng, sau đó lần lượt khởi động các microservice IAM và ứng dụng demo. Nhờ cơ chế healthcheck được cấu hình trong Docker Compose, các service tự động chờ đến khi Kafka và Redis sẵn sàng trước khi khởi tạo kết nối.

0.5.3 Kết quả triển khai

Toàn bộ hệ thống khởi động thành công trên máy cục bộ với thời gian khởi động toàn bộ cụm khoảng 60 – 90 giây, bao gồm cả thời gian cụm Kafka KRaft bầu controller và sẵn sàng nhận kết nối. Sau khi khởi động, người dùng truy cập cổng quản trị IAM qua trình duyệt tại địa chỉ `http://localhost:4200` (chế độ phát triển) hoặc `http://localhost:8080` (qua gateway), và ứng dụng demo tại `http://localhost:8085`. Luồng đăng nhập OAuth2 PKCE, cấp phát quyền, phê duyệt CAB và gửi email thông báo đều hoạt động ổn định trong môi trường này, xác nhận tính tích hợp đầy đủ giữa các thành phần của hệ thống.